

Non-Homomorphic Key Blinding from Symmetric Primitives

Thomas Bellebaum

Fraunhofer AISEC, Lichtenbergstr. 11, 85748 Garching, Germany
`firstname.lastname@aisec.fraunhofer.de`

Abstract. Key Blinding Signature Schemes allow to derive so-called blinded keys from public keys, which can be used to verify signatures created with the secret key. At the same time, neither the blinded keys nor their signatures disclose from which public key they were derived, effectively implementing pseudonyms for one’s identity.

In search of conservative schemes, we deviate from the homomorphism-based re-randomization approach in favor of a novel proof of knowledge-based approach. To authenticate a message, a signer proves that they know an original keypair and a valid way to commit to the corresponding verification key to derive a given blinded key. We provide a framework for such constructions and indicate how MPC-friendly block ciphers and one-way functions may be used for efficient instantiations. While the general framework’s security arguments are stated in the random oracle model, we show a natural instantiation approach whose security can be based on collision-resistance and pseudorandomness instead. The result is the first standard model construction of key blinding.

Using our framework, we identify a shortcoming in the usual definition of *unlinkability* for key blinding signature schemes, which we rectify by considering an additional notion called *targeted unlinkability*.

Keywords: Digital Signatures · Anonymity · Key Blinding.

1 Introduction

Digital Signature Schemes, first proposed by Diffie and Hellman[9], are able to provide data authenticity by assuring that a given message was signed by a private key associated with the public identity key used in the checking procedure. Signature schemes with key blinding capabilities allow the derivation of pseudonymous (“blinded”) identity keys, and authentication of messages under these pseudonyms. Given the public identity key, anyone can derive labeled pseudonyms for an identity, yet authenticating messages for these pseudonyms requires knowledge of the relevant private identity key.

Recent years have seen several applications for key blinding. For instance, both the Tor hidden service protocol [23] and the GNU Name System (GNS) [20] use blinded keys to publish data in distributed hash tables. At a high level, this works by deriving from the identity key and an additional octet string, called

the “label”, both an encryption key and a pseudonym. The data to be published is then encrypted, and the resulting ciphertext signed using the pseudonym. Publishing the signed ciphertext in the distributed hash table, indexed by the pseudonym, ensures that

- each DHT peer implementation can ensure the authenticity of the ciphertext without knowledge of the original identity key or label. Furthermore,
- only clients knowing both the original identity key and the label are able to look up and decrypt published data. Without both of these, it is infeasible to even recognize data published by a particular identity key, or pieces of data published by different pseudonyms of the same key. This provides a basic level of censorship resistance and unlinkability.

Appendix A provides further background information about the relevance of these properties in Tor and GNS. Other use cases of key blinding include private airdrop schemes [24] to pseudonomously claim cryptocurrency payments.

As a first contribution throughout this paper, we recognize that the usual definition of unlinkability for key blinding signature schemes is not strong enough to fully capture the requirements above. In particular, it only asserts that an adversary not knowing any used public keys cannot decide whether two pieces of data were published by the same identity. To remedy this, we consider two distinct notions of unlinkability aimed at different use-cases. *Anonymous* unlinkability is the classical infeasibility for an adversary to detect patterns in blinded public keys and signatures relating to the original keys used, and relies on high public-key entropy. *Targeted* unlinkability on the other hand denotes the inability of an adversary to detect blindings of a known public key, and relies on the entropy of the labels. Using the techniques developed in the coming chapters, we show a separation between these two notions by constructing a key blinding signature scheme which is anonymously unlinkable, yet not targeted unlinkable.

State of the art key blinding schemes (see e.g. [12],[14]) are typically derived from an existing signature scheme by taking a hash of a public key and a label to transform a public key into a blinded one. They then exploit homomorphic dependencies between public and private keys to transform the private key into a matching blinded private key. The blinded key pair may later be used in a signing procedure which resembles the original scheme.

For example, when using discrete-log-based public-private key pairs for a signature scheme such as the one by Schnorr [21], one might transform a public key

$$pk := g^{sk}$$

with matching secret key sk into a blinded public key pk_l for label l by first calculating a “blinding factor” $r \leftarrow H(pk, l)$ and then setting $pk_l \leftarrow pk^r$. The corresponding secret key can be calculated as $sk_l \leftarrow sk \cdot r$ as indeed

$$pk_l = g^{sk \cdot r}.$$

The above method provides unlinkability in the sense that if either pk or l are of sufficient entropy to an adversary, when modelling H as a random oracle, pk_l is

seemingly unrelated to pk and pk_{l^*} for a different label l^* . However, this approach crucially relies on the homomorphic discrete-log relationship between private and public keys. For this reason, it is nontrivial to find alternative one-way relations, an endeavour motivated by the expected advent of a quantum computer, which could solve discrete-log type assumptions in polynomial time.[22]

Work by Eaton et al. [12] has identified similar homomorphic properties in proposed post quantum signature schemes like Dilithium-QROM [16] and LegRoast [3] and used these to design re-randomization routines for the key pairs, resulting in key blinding schemes for these primitives. However, the used primitives achieve their efficiency by exploiting mathematical structure (namely, the homomorphisms). Such primitives tend to give rise to new attacks over time¹. In particular, they were not able to find usable blinding schemes for post quantum signature schemes relying on generic symmetric primitives only.² That is, a construction based on pseudorandom objects (functions, permutations, etc.) and similarly unstructured random (hash) functions.

To avoid reliance on structured primitives and enable more conservative instantiations, in this paper we explore a different approach as our main contribution. Rather than relying on homomorphic properties of the hard instance to re-randomize a public key of an existing signature system, we devise a framework for designing new schemes from the ground up. In doing so, we focus on one-way relations with efficient proofs of knowledge of a preimage. This is motivated in part by recent advances in proof systems, e.g. based on the MPC-in-the-head paradigm by Ishai et. al [15]. However our constructions only rely on generic security definitions of non-interactive zero knowledge proofs, namely zero knowledge and simulation-sound extractability.

To blind a public key, our framework calculates the blinding factor r as before, but uses it as randomness to commit to pk . Formally, let F be any one-way function and C be a commitment routine taking as input a value to commit to and some randomness. Given a key pair (sk, pk) such that

$$pk = F(sk),$$

we derive blinded public keys pk_l as

$$pk_l = C(pk, r)$$

with $r := H(pk, l)$ and implicitly leave

$$sk_l = (sk, r).$$

To sign a message m using a blinded public key pk_l one proves knowledge of a value sk and a value r such that $C(F(sk), r) = pk_l$, incorporating m in

¹ See e.g. [13], slide 10, for lattice based constructions.

² In Appendix C, they mention a scheme based on an encryption of a public key for Picnic like signature schemes, which is very similar to one of our proposals. However, as the authors note, their scheme is susceptible to a simple meet-in-the-middle attack. As we show, this can be mitigated by a simple and cost-efficient feed forward operation.

an extended statement for the proof system, i.e. for instance in a Fiat-Shamir challenge.

We motivate our framework and examine its security in the random oracle model. We provide some context for it by describing how several existing re-randomization based approaches (such as the discrete-log example above) can be seen as variations of the framework by introducing the notion of function-reversible binding for commitment schemes, a strictly weaker property than the more standard binding. Our security arguments show that function-reversible binding alongside unpredictability naturally captures the requirements on the blinding routine to achieve unforgeability in our proof-of-knowledge based setting, while the standard hiding property naturally captures our unlinkability notions.

1.1 A Standard Model Construction

The hash function H deriving the blinding factor deserves particular attention, as it is modeled as a random oracle in our theorems.

We show that a slight variation of our framework allows for unlinkability arguments without random oracles, at the cost of increasing the size of the public key. Namely, assume that each public key is accompanied by an independent key s . Such a value would be generated at random during key generation and from an application’s perspective, it would be regarded as a part of the public key. We may then derive the blinding factor as $r \leftarrow H(s, l)$. This simple change avoids a cyclic dependency when arguing about the computational entropy of commitment randomness, and only requires H to act as a pseudorandom function (if the public key and thus s is unknown) or a computational randomness extractor (if s is known but l is of high entropy). Because our framework encompasses many existing schemes, this construction also applies to those.

The shift from re-randomization to commitment schemes also allows to instantiate the commitment scheme by hashing, using a custom hash function, the public key alongside a random string of sufficient length. We find that doing so lessens the requirements on the random oracle to mere collision resistance for unforgeability. For research on practical schemes, we propose the use of the Davies-Meyer compression function, which complements the ongoing research on MPC-friendly block ciphers. Taken together with the aforementioned random-oracle-free unlinkability arguments, this constitutes the (to our knowledge) first generic standard model construction of key blinding functionality.³

The main appeal of a construction not involving further random oracles is that it avoids additional arguments in the quantum random oracle model, and that it makes very conservative use of hash functions. For applications requiring short public keys, we also highlight a natural construction which uses a random oracle only once to derive s from the public key. We only argue about its security

³ We stress that we do not claim efficient constructions of our primitives (e.g. NIZKs) in the standard model

in the random oracle model and conjecture it to be of sufficient security in the quantum random oracle model.

We also highlight some engineering tricks relevant to applications along the way. For instance, applications encrypting data before signing and publishing it under a pseudonym. With a carefully designed key schedule, encryption keys can be securely derived for each pseudonym, provided that one knows both the original public key and the label of the pseudonym.

1.2 About Reduction Tightness

Our security arguments for the most part reduce tightly to the multi-user security of our primitives, not their single-user security. Moreover, the number of “users” for which we require some primitives to be secure does not correspond to the number of “users” of the key blinding scheme, but rather the number of pseudonyms created by those users. For a framework as generic as ours, this seems natural, as the pseudonyms are supposed to appear as belonging to independent users.

In general, the security notions we consider (e.g. indistinguishability of a pseudorandom function from a truly random one) admit a generic reduction from multi-user to single-user security, albeit with a security loss linear in the number of users (i.e. in some cases, pseudonyms). We argue that this will not pose a significant problem for instantiations: As we discuss below, some weak collision resistance requirements inherent to the key blinding setting dictate the use of primitives with “key lengths” of twice the desired security level. Use of such primitives should in general account for the non-tightness described above.

The exception to this is the one-way function F , which we only need to be secure for the number of users of the key blinding scheme. We leave it as future work to identify practical one-way functions secure in the multi-user setting.

The reductions we describe are efficient and produce a “negligible overhead” over the runtime of a given adversarial algorithm. Concretely, for each oracle call of the adversary our reductions may require a constant number of additional executions of functions provided by the respective primitives, such as PRF evaluations, as well as the aggregation of a constant number of additional items in a set or associative array.

While we formally discuss our framework in the single-user setting for lack of space, we also sketch the derivation of corresponding bounds in a multi-user setting.

1.3 Related Work

Rerandomization of keys, for key blinding and key derivation and along with various security notions, has been studied in previous works. [5] provides an overview. The security notions discussed there tend to be very rerandomization-specific and in general only cover single-target settings. Our definitions extend [12] to the multi-target setting, which is more tailored to key blinding use cases.

With the goal of achieving post-quantum key blinding, [12] proposed several key blinding schemes based on homomorphisms between public and private keys for previously proposed post-quantum secure signature schemes. Their Lemma 2 contains a gap, which we present in Appendix C.1. We argue informally that a slightly adjusted lemma should hold. However, the adjustment calls into question the concrete bounds given in their work. Most relevant to the present discussion is a proposal in their Appendix C based on block ciphers, which does however succumb to a simple meet-in-the-middle attack, as the authors note. As we show in Section 4, a feed-forward operation, which due to its linearity is very efficient in MPC-in-the-Head settings, could thwart this attack by heuristically providing collision resistance in the ideal cipher model.

Parallel to our work, in [2], Balumuri et al. proposed a fix for the meet-in-the-middle attack against the scheme in [12]. However, initially the proposed schemes did not inhibit their proclaimed security against forgery attempts, because of an attack sketched in Appendix C.2. The attack uses the possibility that a pseudonym may be assigned multiple labels and has since been addressed. The arguments in the present paper prevent this attack using a dedicated notion of commitment scheme unpredictability, which is both implied by the more standard hiding and binding notions, as well as easily achieved statistically at the cost of adding a few random bytes to the commitment.

An internet draft in the IRTF Crypto Forum Research Group relates to key blinding [8]. The security of the proposed discrete-log based constructions is discussed in [11].

1.4 Outline and Summary of Constructions

Notation, syntax and security notions are introduced in Section 2.

In Section 3 we introduce our overarching framework $\mathcal{I}_{KB}$ (“Key Blinding”) and motivate its use of a commitment scheme and hash function using a slightly modified yet insecure framework $\mathcal{I}_{pre}$. We establish the relation to re-randomization based constructions and present our formal arguments for the framework’s security.

Section 4 highlights a particularly advantageous implementation of the commitment scheme using a collision resistant hash function, and presents a standard model argument for the unforgeability of $\mathcal{I}_{KB}$ when used with such a hash function.

Section 5 introduces a variation on $\mathcal{I}_{KB}$, called $\mathcal{I}_{SM}$ (“Standard Model”) allowing for standard model unlinkability arguments, as well as $\mathcal{I}'_{KB}$, a partial implementation of the original framework making very conservative use of the hash function.

Finally, Section 6 provides a separation between our unlinkability notions. The resulting construction, $\mathcal{I}_{ER}$ (“Efficiently Recognizable”), allows to efficiently check whether a pseudonym was derived from a given public key, yet different pseudonyms of unknown public keys still appear to be derived from individual public keys.

2 Preliminaries

For a discrete probability distribution $\mathfrak{D}$, we denote by $x \xleftarrow{\$} \mathfrak{D}$ the sampling of a variable x according to $\mathfrak{D}$. If $\mathfrak{D}$ has support D , then its min-entropy is defined as $\min_{d \in D} (-\log_2(\Pr[\mathfrak{D} = d]))$. As a shorthand, we also denote by $x \xleftarrow{\$} \mathcal{S}$ sampling from the uniform distribution over a set $\mathcal{S}$ and by $x \xleftarrow{\$} \mathcal{A}()$ the output of a probabilistic algorithm $\mathcal{A}$ run on uniform randomness. For a deterministic function F , $\mathfrak{D}_F$ denotes the distribution of images obtained by evaluating F on a uniformly random preimage. We write $\mathcal{A}^C()$ to indicate black-box oracle access by $\mathcal{A}$ to an algorithm or function C .

For a given predicate P , $[[P(x)]]$ is defined to be 1 if P applied to x evaluates to *true* and 0 else.

Our security definitions are in terms of concrete runtimes of adversarial algorithms, which we often omit from our security reductions for readability.

2.1 Key Blinding Schemes

A key blinding signature scheme $\mathcal{I} = (\text{KeyGen}, \text{Blind}, \text{Sign}, \text{Verify})$ is a tuple of algorithms, where

- $(sk, pk) \xleftarrow{\$} \text{KeyGen}()$ generates a private-public key pair,
- $pk_l \leftarrow \text{Blind}(pk, l)$ generates a blinded public key for a given label l ,
- $\sigma \xleftarrow{\$} \text{Sign}(sk, m, l)$ signs a message m for verification under label l , and
- $0/1 \leftarrow \text{Verify}(pk_l, m, \sigma)$ verifies a message signature pair given a blinded public key (yet not the label).

We implicitly assume that knowledge of the private key implies knowledge of the public key. As a basic correctness requirement we have that the following algorithm will always output 1 for any label l and message m :

- 1: $(sk, pk) \xleftarrow{\$} \text{KeyGen}()$
- 2: $pk_l \leftarrow \text{Blind}(pk, l)$
- 3: $\sigma \xleftarrow{\$} \text{Sign}(sk, m, l)$
- 4: **return** $\text{Verify}(pk_l, m, \sigma)$

Security definitions for key blinding in the literature tend to either rely heavily on rerandomizability-based constructions (e.g. [5] requires the ability to sign with the original keys), or consider only a single blinding depending on the bit to guess (e.g. [12], [5]), which for non-zero advantages incur a high security loss when arguing for the security of the resulting schemes. The definitions given here are natural adaptations of [12] covering strong unforgeability and a multi-target (i.e. multiple blindings depending on the secret bit) variant of (anonymous) unlinkability.

We require that there shall not exist an efficient algorithm which can forge a new signature on a message label pair. Formally, consider the game SUF-CMA in Figure 1.

Game $\text{SUF-CMA}_{\mathcal{I}}^{\mathcal{A}}()$

1: $(sk, pk) \xleftarrow{\$} \text{KeyGen}()$	
2: $Q \leftarrow \emptyset$	$\underline{S(l, m)}$
3: $(l, m, \sigma) \xleftarrow{\$} \mathcal{A}^S(pk)$	1: $\sigma \xleftarrow{\$} \text{Sign}(pk, m, l)$
4: $pk_l \leftarrow \text{Blind}(pk, l)$	2: $Q \leftarrow Q \cup \{(l, m, \sigma)\}$
5: return $[(l, m, \sigma) \notin Q \wedge \text{Verify}(pk_l, m, \sigma)]$	3: return σ

Fig. 1: (Strong) existential unforgeability under chosen message attack

We say that a scheme $\mathcal{I}$ has (ϵ, t, q_S) -unforgeability if every algorithm $\mathcal{A}$ running in time t and making at most q_S signing queries, we have that

$$\Pr[\text{SUF-CMA}_{\mathcal{I}}^{\mathcal{A}}()] \leq \epsilon.$$

(ϵ, u, t, q_S) -multiuser-unforgeability is defined analogously, except that the game generates u key pairs given to $\mathcal{A}$, signing queries additionally take the index of the key pair to use, Q tracks tuples containing this index, and $\mathcal{A}$ must additionally output an index for its forgery.

Our privacy goals come in two forms. For the first form, we require that it shall be hard to correlate signatures and blinded public keys for unknown public keys. We call this **anonymous unlinkability** and define its security via the game AUL-CMA in Figure 2.

Game $\text{AUL-CMA}_{\mathcal{I}}^{\mathcal{A}}()$

1: $(sk, pk) \xleftarrow{\$} \text{KeyGen}()$	
2: $Q \leftarrow \emptyset$	$\underline{B_b(l \notin Q)}$
3: $b^* \xleftarrow{\$} \{0, 1\}$	1: if $b = 1$ then
4: $b \leftarrow \mathcal{A}^{B_0, B_{b^*}, S}()$	2: $Q[l] \xleftarrow{\$} \text{KeyGen}()$
5: return $[b = b^*]$	3: else
$\underline{S(l \in Q, m)}$	4: $Q[l] \leftarrow (sk, pk)$
1: $\sigma \xleftarrow{\$} \text{Sign}(Q[l].sk, m, l)$	5: end if
2: return σ	6: $pk_l \leftarrow \text{Blind}(Q[l].pk, l)$
	7: return pk_l

Fig. 2: Anonymous unlinkability security game

We say that a scheme $\mathcal{I}$ has anonymous (ϵ, t, q_B, q_S) -unlinkability if every algorithm $\mathcal{A}$ running in time t and making at most q_B blinding and q_S signing queries, we have that

$$2 \cdot |\Pr[\text{AUL-CMA}_{\mathcal{I}}^{\mathcal{A}}()] - \frac{1}{2}| \leq \epsilon.$$

Anonymous $(\epsilon, u, t, q_B, q_S)$ -multiuser-unlinkability is defined analogously, except that the game generates u key pairs during setup, and the first argument

to any query, and index into Q , is a tuple (i, l) with i being the index of the key pair to use if $b^* = 0$.

Some more recent applications of key blinding require a different kind of unlinkability, namely that even when the public key is known, it shall be hard to recognize blinded public keys and signatures derived from that key, provided that the labels used for blinding have sufficient entropy. To formalize this notion of **targeted unlinkability**, consider the game TUL-CMA in Figure 3, parameterized with a distribution $\mathfrak{D}$ of labels.

Game $\text{TUL-CMA}_{\mathcal{I}, \mathfrak{D}}^{\mathcal{A}}()$

1: $(sk, pk) \xleftarrow{\$} \text{KeyGen}()$	$B_b()$
2: $n \leftarrow 0$	1: $n \leftarrow n + 1$
3: $b^* \xleftarrow{\$} \{0, 1\}$	2: $l_n \xleftarrow{\$} \mathfrak{D}$
4: $b \leftarrow \mathcal{A}^{B_{b^*}, S}(pk)$	3: if $b = 1$ then
5: return $[[b = b^*]]$	4: $(sk_n, pk_n) \xleftarrow{\$} \text{KeyGen}()$
$S(i \leq n, m)$	5: else
1: $\sigma \xleftarrow{\$} \text{Sign}(sk_i, m, l_i)$	6: $(sk_n, pk_n) \leftarrow (sk, pk)$
2: return σ	7: end if
	8: return $\text{Blind}(pk_i, l_i)$

Fig. 3: Targeted unlinkability security game

Given a distribution $\mathfrak{D}$, we say that a scheme $\mathcal{I}$ has targeted (ϵ, t, q_B, q_S) -unlinkability with respect to $\mathfrak{D}$ if every algorithm $\mathcal{A}$ running in time t and making at most q_B blinding and q_S signing queries, we have that

$$2 \cdot |\Pr[\text{TUL-CMA}_{\mathcal{I}, \mathfrak{D}}^{\mathcal{A}}()] - \frac{1}{2}| \leq \epsilon.$$

Targeted $(\epsilon, u, t, q_B, q_S)$ -multiuser-unlinkability is defined analogously, except that the game generates u key pairs given to $\mathcal{A}$ and blinding queries additionally take the index of the key pair to use if $b^* = 0$.

2.2 Symmetric primitives and NIZK Arguments

We make use of standard definitions of single- and multiuser security of oneway functions, pseudorandom functions and permutations, hash functions, randomness extractors, and non-interactive zero knowledge arguments, which can be found in Appendix B.

Commitment Schemes A (non-interactive) commitment scheme is a function $C : \mathcal{X} \times \mathcal{R} \rightarrow \mathcal{Y}$.

A commitment scheme is called (ϵ, t) -binding if for every efficiently constructable algorithm $\mathcal{A}$ running in time t it holds that

$$\Pr[x_1 \neq x_2 \wedge C(x_1, r_1) = C(x_2, r_2) : (x_1, r_1, x_2, r_2) \xleftarrow{\$} \mathcal{A}()] \leq \epsilon.$$

A commitment scheme is (ϵ, t, q) -hiding if for every algorithm running in time t and making at most q oracle queries we have

$$|\Pr[\mathcal{A}^{C_0}() = 1] - \Pr[\mathcal{A}^{C_1}() = 1]| \leq \epsilon$$

where oracle $C_b(x_0, x_1)$ picks $r \xleftarrow{\$} \mathcal{R}$ and returns $C(x_b, r)$ for each query.

Finally, our reductions require a weak, nonstandard form of collision resistance against the a class of trivial attacks: Let $\mathfrak{D}$ be an efficiently sampleable distribution supported on $\mathcal{X}$. A commitment scheme has (ϵ, q) -unpredictable commitments w.r.t. $\mathfrak{D}$ if the following algorithm returns 1 with probability at most ϵ :

```

1:  $x \xleftarrow{\$} \mathfrak{D}$ 
2: for  $i \in [q]$  do
3:    $r_i \xleftarrow{\$} \mathcal{R}$ 
4:    $c_i \leftarrow C(x, r_i)$ 
5: end for
6: return  $[[\exists i, j \in [q]. c_i = c_j]]$ 

```

If needed, this technical requirement can be met statistically by adding additional unused bits in r to the output of C . More conveniently, it is also met if C is fully collision resistant and $\mathcal{R}$ is large. Finally, as a result of the following remark, a limited amount of unpredictability is inherent to most standard commitment schemes.

Remark 1. Let $\mathfrak{D}$ be efficiently sampleable and $q < |\mathcal{X}|$. Assume that C is a (ϵ_B, t_B) -binding and (ϵ_H, t_H, q) -hiding commitment scheme, where t_H and t_B are the runtimes of the algorithms $\mathcal{A}$ and $\mathcal{B}$ given below. Then C has $(\epsilon_B + \epsilon_H, q)$ -unpredictable commitments.

Proof. Let $\mathcal{A}$ be an adversary against the hiding property of C . $\mathcal{A}$ generates q different inputs $x_i \in \mathcal{X}$, samples $x \xleftarrow{\$} \mathfrak{D}$, and makes q queries with input (x, x_i) to its oracle. It then outputs 1 iff the returned commitments collide.

Next, let $\mathcal{B}$ be an adversary against the binding property of C . It generates the same q inputs $x_i \in \mathcal{X}$ as $\mathcal{A}$, samples q randomness values $r_i \xleftarrow{\$} \mathcal{R}$ and computes q commitments $c_i \leftarrow C(x_i, r_i)$. Finally, it outputs a collision $C(x_i, r_i) = C(x_j, r_j)$, $i \neq j$ if one exists (and a dummy value else).

Note that the probability that $\mathcal{A}$ outputs 1 is the unpredictability of C if its oracle commits to its first input, and the probability that $\mathcal{B}$ outputs a collision in C if its oracle commits to its second input. By the hiding assumption on C , these probabilities will differ by at most ϵ_H . But since every collision output by $\mathcal{B}$ has distinct inputs for C , by the binding assumption, it outputs such a collision with probability at most ϵ_B . $\square$

2.3 Idealized primitives

We will give heuristic security arguments assuming the existence of the following idealized primitives:

Random Oracle We might assume that a hash function H behaves like an ideal random function, with which the adversary may only interact by querying an additional oracle evaluating the random function.

Ideal Cipher We might assume that a block cipher E behaves like an ideal and independent random permutation for each specified key, with which the adversary may only interact by querying two oracles evaluating E and E^{-1} .

Our arguments will assume that any inputs and outputs of these oracle queries become known to the security game.

3 Blindings and Commitments

Let $\mathcal{SK}$, $\mathcal{PK}$ and $\mathcal{BPK}$ be sets of secret, public and blinded public keys, respectively. Further, let $\mathcal{L}$ be a set of labels and $\mathcal{R}$ be a set of random seeds. In many instantiations, we expect these to be bit strings of a given length, but we prefer to work with the general set notation for readability. We similarly denote the set of possible messages to be signed as $\mathcal{M}$.

Assume we are given the following primitives:

- A one-way function $F : \mathcal{SK} \rightarrow \mathcal{PK}$
- A hash function $H : \mathcal{PK} \times \mathcal{L} \rightarrow \mathcal{R}$
- A commitment scheme $C : \mathcal{PK} \times \mathcal{R} \rightarrow \mathcal{BPK}$
- A NIZK $\mathcal{P}$ for the following NP-relation:

$$\mathfrak{R} := \{((bpk, m), (sk, r)) \in (\mathcal{BPK} \times \mathcal{M}) \times (\mathcal{SK} \times \mathcal{R}) : C(F(sk), r) = bpk\}$$

Our main proposal is the following framework $\mathcal{I}_{KB}$ for designing key blinding signature schemes:

Construction $\mathcal{I}_{KB}$

def KEYGEN():

$sk \xleftarrow{\$} \mathcal{SK}$
 $pk \leftarrow F(sk)$
return (sk, pk)

def BLIND(pk, l):

$r \leftarrow H(pk, l)$
 $pk_l \leftarrow C(pk, r)$
return pk_l

def SIGN(sk, m, l):

$r \leftarrow H(pk, l)$
 $pk_l \leftarrow C(pk, r)$
 $\sigma \xleftarrow{\$} \mathcal{P}.Prove((pk_l, m), (sk, r))$
return σ

def VERIFY(pk_l, m, σ):

return $\mathcal{P}.Verify((pk_l, m), \sigma)$

To motivate the use of a commitment scheme to address the key blinding scenario, consider a related scheme, denoted $\mathcal{I}_{pre}$, defined identically to $\mathcal{I}_{KB}$

except that the first line of the *Blind* and *Sign* routines reads as $r \leftarrow l$, i.e. we omit the hash function (assuming $\mathcal{L} = \mathcal{R}$).

In $\mathcal{I}_{pre}$, the hiding property of the commitment scheme ensures a simple kind of targeted unlinkability: If the envisioned distribution $\mathfrak{D}$ of labels is the uniform distribution over $\mathcal{R}$, we expect that any efficient distinguisher in the TUL-CMA security experiment must have gotten a “clue” as to which public key was in use by either the signing oracle, whose responses are supposed to be zero-knowledge, or the blinding oracle, whose responses are supposed to be hiding commitments to the public key. Both potential sources of information in this game would thus be indicative of a vulnerability of the primitives.

For other distributions of labels however, especially adversarially chosen ones as in the anonymous unlinkability experiment, we can not make this deduction without assuming further, stronger properties of the commitment routine. It is conceivable that one could rule out generic attacks using C as a black box by modelling it as an ideal primitive.⁴ However, both $\mathcal{I}_{pre}$ and $\mathcal{I}_{KB}$ require an argument of knowledge over the circuit of C , and the size of such proofs tends to increase with the commitment schemes’ complexity. By relying only on standard commitment scheme properties we hope to create more efficient schemes. $\mathcal{I}_{KB}$ attempts to “smooth out” the randomness for C using a hash function. The efficiency and structure of this function is secondary, as it is not part of the argument of knowledge. In the arguments of this section, we model H as a random oracle, which we believe to be a reasonable choice for modern cryptographic hash functions. We will argue that as long as either public keys (as generated by the key generation function) or labels have sufficient min-entropy, a random oracle can extract uniform randomness for C . However, since the use of an idealized component raises the question of post-quantum security of this framework, Section 5 will explore reasonable implementations of H based on pseudorandomness and randomness extraction.

The task of forging a signature can be broken down into two distinct approaches. Reuse of a given statement and proof requires finding a second public key - label pair from which the same blinded public key can be derived. This can thus be prevented by collision resistance of the *Blind*-routine. The next section explores a collision resistant implementation of C , which together with collision resistance of H would imply this for $\mathcal{I}_{KB}$. Here, by again modelling H as a random oracle, we can once again lessen the requirements on C to binding and unpredictability, which by an earlier remark is easy to achieve for standard commitment schemes.

Note that a mild form of a collision resistance requirement is inherent to key blinding schemes, rather than just our framework. Assume that an adversary

⁴ Conducting an argument of knowledge over a random oracle is not a meaningful operation. Instead, a more formal argument needs to formally define the security properties required of the actual implementation of C and may then prove that a random oracle would fulfill these properties. The random oracle heuristic is then to assume that a sufficiently unstructured implementation of C also fulfills this property. We use this technique multiple times throughout this paper.

blinds a public key pk an expected $O(\sqrt{|\mathcal{BPK}|})$ times to achieve a collision $Blind(pk, l_1) = Blind(pk, l_2)$. Since each message-signature pair verifies just based on the blinded public key, any valid signature for the l_1 -pseudonym of pk is also a valid signature for its l_2 -pseudonym, for the same message.

Forgery of a new tuple of blinded public key, message and signature, even in $\mathcal{I}_{pre}$, corresponds to creating a new valid statement-proof pair for $\mathcal{P}$. Assuming the zero knowledge and simulation sound extractability properties of $\mathcal{P}$, this can only be done with knowledge of a corresponding secret key sk and randomness r . However, such knowledge would either imply an inversion of F on the public key under attack, or a second opening of the blind public key under a different public key.

3.1 Function-Reversible Binding

Comparing the discrete-log based example from the introduction to $\mathcal{I}_{KB}$, a common structure becomes apparent. Indeed, by suitably balancing the security properties of C and F , many rerandomization-based schemes can be recast as nontrivial instantiations of $\mathcal{I}_{KB}$.

To illustrate this, assume that a key blinding scheme calculates $r \leftarrow H(pk, l)$ and then separately blinds the public and secret key using two functions

$$bpk \leftarrow BlindPK(pk, r) \quad \text{and} \quad bsk \leftarrow BlindSK(sk, r)$$

Assume further that the signatures created for this blinded key pair are arguments of knowledge of the secret key, that we know a value $\hat{r}$ such that $BlindPK(pk, \hat{r}) = pk$ for all $pk \in \mathcal{PK}$ and that there is an efficient function $UnblindSK$ which on input a blind secret key and r outputs the original secret key.

For concreteness, with the discrete-log based example we have $BlindPK(pk, r) := pk^r$, $BlindSK(sk, r) := sk \cdot r$, $\hat{r} = 1$ and $UnblindSK(bsk, r) := sk \cdot r^{-1}$. Schnorr signatures are proofs of knowledge of bsk .

Such a scheme can be recast as an instantiation of $\mathcal{I}_{KB}$ by defining

$$C(pk, r) := BlindPK(pk, r)$$

and reinterpreting the argument of knowledge of bsk as an argument of knowledge of *some tuple* (sk, r) deriving bpk . Indeed, knowledge of bsk implies the knowledge of the tuple $(bsk, \hat{r})$ with this property.

Although syntactically correct, the informal security argument given above does not capture this instantiation. In particular, C might not be binding. For the discrete-log example, we have $BlindPK(pk, r) = BlindPK(pk^s, r \cdot s^{-1})$ for any scalar s . In effect, this might make finding any tuple (sk, r) deriving bpk much easier than inverting F . This is where $UnblindSK$ comes in. It ensures that any such tuple (including $(bsk, \hat{r})$) can be used to derive sk , thus inverting F on pk .

In order to give a security argument for $\mathcal{I}_{KB}$ capturing the above strategy for instantiation, we define a weaker variant of binding for commitment schemes which we call F -reversible binding.

Game $F\text{-RB}_{C,reverse}^{\mathcal{A}}()$

-
- 1: $(x_0, r_0, y_1, r_1) \leftarrow \mathcal{A}()$
 - 2: $y_0 \leftarrow F(x_0)$
 - 3: $x_1 \leftarrow reverse(x_0, (y_0, r_0), (y_1, r_1))$
 - 4: **return** $[[C(y_0, r_0) = C(y_1, r_1) \wedge F(x_1) \neq y_1]]$

Fig. 5: F -reversible binding security game

Let $F : \mathcal{X} \rightarrow \mathcal{Y}$ be a function and consider the game $F\text{-RB}$ in Figure 5. We say that a commitment scheme $C : \mathcal{Y} \times \mathcal{R} \rightarrow \mathcal{Z}$ is (ϵ, t) - F -reversably binding, if there exists an efficiently computable function $reverse : \mathcal{X} \times (\mathcal{Y} \times \mathcal{R})^2 \rightarrow \mathcal{X}$ such that for every adversary $\mathcal{A}$ running in time at most t , we have

$$\Pr[F\text{-RB}_{C,reverse}^{\mathcal{A}}()] \leq \epsilon()$$

Intuitively, the definition guarantees that whenever a commitment can be opened to multiple values, knowledge of an F -preimage of one value implies knowledge of an F -preimage of all others. For the schemes discussed in this subsection, we would have

$$reverse(sk_0, (pk_0, r_0), (pk_1, r_1)) := BlindSK(UnblindSK(sk_0, r_0), r_1)$$

Remark 2. If C is a (ϵ, t) -binding commitment scheme, then C is (ϵ, t) - F -reversably binding for any function F .

3.2 Security Arguments

We can now state our formal security arguments, beginning with unforgeability. For clarity, we present our arguments in the single-user setting and then describe the necessary changes in the multi-user setting.

Theorem 1. *Let H be a random oracle permitting q_H queries. Then framework $\mathcal{I}_{KB}$ provides (ϵ_{UF}, q_S) -unforgeability, provided that*

- F is ϵ_{OW} -oneway,
- C is ϵ_{FR} - F -reversably binding and $(\epsilon_U, q_H + q_S + 1)$ -unpredictable w.r.t. $\mathfrak{D}_F$,
- $\mathcal{P}$ is (ϵ_{ZK}, q_S) -zero knowledge and (ϵ_{SSE}, q_S) -simulation-sound extractable

against adversaries of similar runtime, where

$$\epsilon_{UF} \leq \epsilon_{SSE} + \epsilon_{ZK} + \epsilon_{OW} + \epsilon_{FR} + \epsilon_U$$

Proof. Let $\mathcal{A}$ be an algorithm. Throughout, let (sk^*, pk^*) and (l^*, m^*, σ^*) denote the game's key pair and $\mathcal{A}$'s output, respectively. Assume wlog. that the adversary queried the random oracle at (pk^*, l^*) and at (pk^*, l) for every query to sign a message with label l , and that the adversary never repeats oracle queries to H . If necessary, this can be enforced by considering an adversary $\mathcal{A}'$ which

internally runs $\mathcal{A}$, caches random oracle responses and performs up to $q_S + 1$ additional random oracle queries as necessary.

We consider a series of games G_0 - G_3 with associated probabilities $p_i := \Pr[G_i^{\mathcal{A}}()]$. Let G_0 denote the original SUF-CMA game against $\mathcal{I}_{KB}$. It is clear that $\epsilon_{UF} = p_0$.

Let G_1 be identical to G_0 , except that if $C(pk^*, H(pk^*, l^*))$ equals the value $pk_{l'}$ derived during any signing query (l', m) with $l' \neq l^*$, G_1 always outputs 0. Note that pk^* is distributed according to the key generation algorithm and that $\mathcal{A}$ has queried the random oracle with both (pk^*, l^*) and (pk^*, l') . Since every random oracle query, along with its return value r_i uniquely defines a commitment $C(pk^*, r_i)$, if G_0 and G_1 have different outputs, two such commitments must have collided.⁵ By assumption on C , this happens with probability at most

$$|p_0 - p_1| \leq \epsilon_U$$

Next, let G_2 be identical to G_1 except that the signing oracle calculates $\mathcal{P}.Sim((pk_l, m))$ instead of $\mathcal{P}.Prove((pk_l, m), (sk, r))$. Let $\mathcal{C}$ be an algorithm in the zero-knowledge security game against $\mathcal{P}$, simulating games G_1/G_2 to $\mathcal{A}$ and creating proofs during signing queries by querying its oracle. $\mathcal{C}$ outputs 1 iff G_1/G_2 outputs 1. By assumption on $\mathcal{P}$, since $\mathcal{C}$ perfectly simulates G_1 or G_2 , depending on its oracle, we have

$$|p_1 - p_2| \leq \epsilon_{ZK}$$

Let G_3 be identical to G_2 except that after the adversary has finished, if they has found a valid forgery, G_3 executes

$$(sk', r') \leftarrow Ext((pk_{l^*}, m^*), \sigma^*)$$

and outputs 0 if $C(F(sk'), r') \neq pk_{l^*}$.

Assume that G_3 outputs 1. Because $pk_{l^*}^*$ was never a blinded public key derived during a signing query (l, m^*) with $l \neq l^*$ by the restriction imposed with game G_1 , if $\mathcal{A}$ outputs a valid forgery, σ^* cannot have been the result of the simulator producing a proof for statement (pk_{l^*}, m^*) . Let $\mathcal{D}$ be an algorithm in the SSE security game against $\mathcal{P}$ simulating games G_2/G_3 to $\mathcal{A}$ and simulating proofs during signing queries by querying its oracle. Once $\mathcal{A}$ exits, $\mathcal{D}$ constructs and outputs $((pk_{l^*}, m^*), \sigma^*)$. By assumption on $\mathcal{P}$, since the SSE security games output 1 iff G_2 resp. G_3 output 1, we have

$$|p_2 - p_3| \leq \epsilon_{SSE}$$

Finally, assuming G_3 outputs 1,

- If $reverse(sk', F(sk'), r', pk^*, H(pk^*, l^*))$ yields a value sk^* such that $F(sk^*) = pk^*$, $\mathcal{A}$ has successfully inverted F . Let $\mathcal{E}$ be an algorithm against the one-wayness of F , taking pk^* as input and simulating G_3 to $\mathcal{A}$ (Note that G_3 never uses sk^*). $\mathcal{E}$ then outputs the result of the above *reverse* function call.

⁵ This argument includes the case of random oracle collisions. Note that the unpredictability experiment samples randomness with possible repetition.

- Else, $(sk', r', pk^*, H(pk^*, l^*))$ is a tuple winning the F -reversible binding game. Let $\mathcal{F}$ be an algorithm simulating G_3 to $\mathcal{A}$ and outputting the above tuple.

Since the union of the above events is the event of G_3 outputting 1, we have by the assumptions on F and C that

$$p_3 \leq \epsilon_F + \epsilon_{FR}$$

Collecting the bounds yields the theorem. $\square$

In the multiuser setting, most of the above analysis is almost identical. Let us point out the major differences:

- Starting from G_1 , we need to reject collisions of pseudonyms. These can have three different causes. First, two users can share a public key. Second, there can be collisions of pseudonyms of different public keys. And finally, for each user, there may be collisions in that user's pseudonyms for different labels. While there exist reductions to the one-wayness of F , the binding of C , and (once for each user) C 's unpredictability, respectively, the next section highlights a better approach to deal with the latter two, provided that C and H are collision resistant.
- In game G_3 , we recover the preimage of only one one-way function image, namely for the public key indicated by the adversary. Thus, $\mathcal{E}$ reduces tightly to the multi-target security of F , rather than its single-target security.

We next turn to unlinkability.

Theorem 2. *Let H be modeled as a random oracle permitting q_H queries and $\mathcal{D}$ be a distribution of labels. Then framework $\mathcal{I}_{KB}$ provides $(\epsilon_{TUL}, q_B, q_S)$ -targeted unlinkability w.r.t. $\mathcal{D}$, provided that*

- $\mathcal{D}$ has min-entropy h_D ,
- C is (ϵ_H, q_B) -hiding,
- $\mathcal{P}$ is (ϵ_{ZK}, q_S) -zero knowledge

against adversaries of similar runtime, where

$$\epsilon_{TUL} \leq 2\epsilon_{ZK} + 2q_H \cdot q_B \cdot 2^{-h_D} + \epsilon_H$$

Proof. Let $\mathcal{A}$ be an algorithm. We will again construct a series of games G_0 - G_2 with associated probabilities $p_i = \Pr[G_i^{\mathcal{A}}()]$. Let G_0 denote the original TUL-CMA attack game. It is clear that $2|p_0 - \frac{1}{2}| = \epsilon_{TUL}$.

Let G_1 be identical to G_0 except that signing queries are answered using the simulator Sim instead of $Prove$. Let $\mathcal{B}$ be an algorithm in the zero-knowledge security game against $\mathcal{P}$, simulating games G_0/G_1 to $\mathcal{A}$ and creating proofs during signing queries by querying its oracle. $\mathcal{B}$ outputs 1 iff G_0/G_1 outputs 1. By assumption on $\mathcal{P}$, since $\mathcal{B}$ perfectly simulates G_0 or G_1 , depending on its oracle, we have

$$|p_0 - p_1| \leq \epsilon_{ZK}$$

Next, let G_2 be identical to G_1 except that blinding queries choose a random $r \xleftarrow{\$} \mathcal{R}$ independent of H . $\mathcal{A}$ may only notice the discrepancy when querying H with the correct random label. Since the random labels are otherwise independent of $\mathcal{A}$'s view, we can bound the probability of matching any particular label in a given random oracle query by 2^{-h_D} . Taking the union of such events over at most q_H queries and q_B labels, we have

$$|p_1 - p_2| \leq q_H \cdot q_B \cdot 2^{-h_D}$$

Finally, in G_2 the adversary can only acquire information about b^* from random commitments to either pk or newly generated keys. Let $\mathcal{C}$ be an algorithm in the hiding security game against C , simulating G_2 to $\mathcal{A}$ and blinding keys by calling its own oracle on (pk_0^*, pk_1^*) , where pk_b^* is the public key chosen by B_b in G_2 . The blinded keys obtained this way are returned to $\mathcal{A}$ for blinding queries and reused during signing queries. $\mathcal{C}$ returns the output of $\mathcal{A}$. Let p_2^i be the probability of $\mathcal{A}$ outputting 1 if $b^* = i$. Since $\mathcal{C}$ perfectly simulates G_2 conditioned on either $b^* = 0$ or $b^* = 1$, depending on its oracle, we have by assumption on C that $|p_2^0 - p_2^1| \leq \epsilon_H$ and thus

$$2|p_2 - \frac{1}{2}| = 2|\frac{1}{2}(p_2^1 + (1 - p_2^0)) - \frac{1}{2}| \leq \epsilon_H$$

Collecting the bounds yields the theorem. $\square$

An identical analysis shows the same bound to be true in the multi-user setting.

The proof for anonymous unlinkability is similar to the above, with the entropy of public keys taking the place of the entropy of labels. The only slight complication arises in bounding the difference between games G_1 and G_2 . We would like to argue that an adversary cannot gather any information about the randomized labels because they would have to guess the public key, which would be as independent of their view as the labels in the previous proof. However, this might not be the case. Indeed, an imperfectly hiding commitment scheme may leak information on the public key. We handle this by constructing an additional algorithm to bound the probability of queries to the public keys.

Theorem 3. *Let H be modeled as a random oracle permitting q_H queries. Then framework $\mathcal{I}_{KB}$ provides $(\epsilon_{AUL}, q_B, q_S)$ -anonymous unlinkability, provided that*

- $\mathcal{D}_F$ has min-entropy h_F ,
- C is (ϵ_H, q_B) -hiding,
- $\mathcal{P}$ is (ϵ_{ZK}, q_S) -zero knowledge

against adversaries of similar runtime, where

$$\epsilon_{AUL} \leq 2\epsilon_{ZK} + 2q_H \cdot 2^{-h_F} + 3\epsilon_H$$

Proof. Let $\mathcal{A}$ be an algorithm which (wlog) never repeats queries to the random oracle. As before, we will construct a series of games G_0 - G_2 with associated probabilities $p_i = \Pr[G_i^{\mathcal{A}}()]$. Let G_0 denote the original AUL-CMA attack game. It is clear that $2|p_0 - \frac{1}{2}| = \epsilon_{AUL}$.

Let G_1 be identical to G_0 except that signing queries are answered using the simulator Sim instead of $Prove$. Let $\mathcal{B}$ be an algorithm in the zero-knowledge security game against $\mathcal{P}$, simulating games G_0/G_1 to $\mathcal{A}$ and creating proofs during signing queries by querying its oracle. $\mathcal{B}$ outputs 1 iff G_0/G_1 outputs 1. By assumption on $\mathcal{P}$, since $\mathcal{B}$ perfectly simulates G_0 or G_1 , depending on its oracle, we have

$$|p_0 - p_1| \leq \epsilon_{ZK}$$

Let G_2 be identical to G_1 except that blinding queries choose a random $r \xleftarrow{\$} \mathcal{R}$ independent of H . The adversary may only notice the discrepancy when querying H with one of the game's chosen public keys, for a matching label. We claim that this happens with probability at most

$$|p_1 - p_2| \leq q_H \cdot 2^{-h_F} + \epsilon_H$$

Algorithm $\mathcal{C}^O$

<pre> 1: $(sk, pk) \xleftarrow{\\$} \mathcal{I}_{KB}.KeyGen()$ 2: $(sk_d, pk_d) \xleftarrow{\\$} \mathcal{I}_{KB}.KeyGen()$ 3: $Q \leftarrow \emptyset, Q_H \leftarrow \emptyset$ 4: $b \xleftarrow{\\$} \{0, 1\}$ 5: $b' \leftarrow \mathcal{A}^{B_0, B_b, S, H}()$ 6: return 0 </pre>	<pre> $S(l \in Q, m)$ 1: $\sigma \xleftarrow{\\$} Sim((pk_l, m))$ 2: return σ </pre>
<pre> $H(pk, l)$ 1: if $pk = Q[l].pk$ then 2: abort game and return 1 3: end if 4: $Q_H \leftarrow Q_H \cup \{(pk, l)\}$ 5: $k \xleftarrow{\\$} \mathcal{K}$ 6: return k </pre>	<pre> $B_b(l \notin Q)$ 1: if $b = 1$ then 2: $Q[l] \xleftarrow{\\$} \mathcal{I}_{KB}.KeyGen()$ 3: else 4: $Q[l] \leftarrow (sk, pk)$ 5: end if 6: if $(Q[l].pk, l) \in Q_H$ then 7: abort game and return 1 8: end if 9: $pk_l \leftarrow O(Q[l].pk, pk_d)$ 10: return pk_l </pre>

Fig. 6: Algorithm $\mathcal{C}$ demonstrating an attack against the hiding property of C

To see this, consider algorithm $\mathcal{C}$ in Figure 6 against the hiding property of C . Assume that O commits to its first argument. Then $\mathcal{C}$ outputs the event that $\mathcal{A}$'s queries to H overlap with the derivation queries of r in G_1 , which until that point it perfectly simulates to $\mathcal{A}$. If O instead only commits to the decoy public key pk_d , then $\mathcal{A}$'s view is independent of $Q[l].pk$, and thus $\mathcal{A}$ can at best guess those public keys, which amounts to at most a $q_H \cdot 2^{-h_F}$ chance of querying for such a key, since labels are distinct for these keys. Thus, by assumption on C ,

the probability of guessing one of the public keys can increase by at most ϵ_H when committing to the actual keys.

Finally, in G_2 the adversary can only acquire information about b^* from random commitments to either pk or newly generated keys. Let $\mathcal{D}$ be an algorithm in the hiding security game against C , simulating G_3 to $\mathcal{A}$ and answering queries to $\mathcal{A}$'s second oracle by setting pk_l to the output of its own oracle, queried on (pk_0^*, pk_1^*) , where pk_b^* is the public key chosen by B_b in G_2 . The returned blinded keys are then also reused for signing queries. $\mathcal{D}$ returns the output of $\mathcal{A}$. Let p_2^i be the probability of $\mathcal{A}$ outputting 1 if $b^* = i$. Since $\mathcal{C}$ perfectly simulates G_2 conditioned on either $b^* = 0$ or $b^* = 1$, depending on its oracle, we have by assumption on C that $|p_2^0 - p_2^1| \leq \epsilon_H$ and thus

$$2|p_2 - \frac{1}{2}| = 2|\frac{1}{2}(p_2^1 + (1 - p_2^0)) - \frac{1}{2}| = |p_2^0 - p_2^1| \leq \epsilon_H$$

Collecting the bounds yields the theorem. $\square$

An almost identical analysis carries over to the multi-user setting. The major difference lies in the definition and analysis of algorithm $\mathcal{C}$, which needs to generate u decoy key pairs and use the i -th decoy key in blinding queries for the i -th key. If its oracle O commits to the decoy keys, $\mathcal{A}$'s odds of guessing *any* of the blinding keys $Q[(i, l)].pk$ for a given label l increase u -fold, since each user's public key can be blinded using the same label. The corresponding bound in the multi-user setting is therefore

$$|p_1 - p_2| \leq u \cdot q_H \cdot 2^{-h_F} + \epsilon_H$$

4 Leveraging Collision Resistance and Block Ciphers

In this section, we focus on commitment schemes with collision resistance, i.e. for which it is hard to find $(pk_0, r_0) \neq (pk_1, r_1)$ s.t. $C(pk_0, r_0) = C(pk_1, r_1)$. Indeed, a well-known textbook example of a commitment scheme takes C to be a cryptographic hash function.

Collision resistance simplifies the unforgeability analysis from the previous section:

1. Collision resistance implies binding, since an opening of a commitment to two distinct inputs constitutes a collision.
2. If the commitment scheme takes enough randomness, collision resistance, even without unlinkability, implies unpredictability, since the unpredictability experiment can only be won with a collision in either the randomness values or the commitment scheme. Moreover, in a multiuser-setting it can tightly prevent collisions of pseudonyms of different public keys or different labels.
3. Collision resistance of C can be used to replace the random oracle in the unforgeability argument with a collision resistant H .

That last point is of particular interest, because a random oracle is not a suitable representation of an adversary’s black box function analysis capabilities, when given access to a quantum computer [4]. Rather than concerning us with the peculiarities of the quantum random oracle model, a standard model argument, if sufficiently comprehensible and not forcing unwarranted changes upon the construction, can contribute to simpler understanding of the scheme’s security.

The technical reason for why collision resistance of H is sufficient lies in a loss of generality: An unpredictable commitment scheme, as is implied by hiding and binding, only guarantees that collisions will never occur if the commitment scheme is used with uniform randomness. In contrast, a collision resistant commitment scheme provides the same guarantee as long as randomness values are *distinct*.

Beside the security argument simplifications, a collision resistance based argument lends itself well to a block cipher based instantiation approach via the well known Davies-Meyer compression function. To highlight this approach, let $E : \mathcal{R} \times \mathcal{PK} \rightarrow \mathcal{PK}$ be a block cipher and define the following commitment scheme:

$$C(x, k) := E(k, x) \oplus x$$

This commitment scheme becomes particularly favorable when used in conjunction with an MPC-in-the-Head based proof system, since signature schemes like Picnic [6] have sparked research into MPC-friendly block ciphers for digital signatures [10]. Moreover, the exclusive or operation is usually very efficient to perform in a secret-shared environment, due to its linearity.

We note that instantiating $\mathcal{I}_{KB}$ with the Davies-Meyer compression function as C and the one-way function $F(x) := E(x, 0)$ (with 0 an arbitrary constant), one derives a scheme very similar to the one proposed in Appendix C of [12], but with just one additional exclusive or operation.⁶

We will start by formally arguing that the Davies-Meyer construction may indeed be used as a commitment scheme. While the arguments are standard, we include them in Appendices D.1 and D.2 for self-containment.

Lemma 1. *Let E be a (ϵ, q, q) -multiuser-pseudorandom function. Then the commitment scheme defined by $C(x, r) := E(r, x) \oplus x$ is $(2\epsilon, q)$ -hiding.*

Lemma 2. *Let E be modeled as an ideal cipher permitting q queries. Then C is ϵ -collision resistant with*

$$\epsilon \leq \frac{(q+2)^2}{|\mathcal{X}|}$$

The following theorem is an alternative to Theorem 1. Note that it is concerned with a generic collision resistant function C , even though the suggested implementation above uses an ideal component to argue *heuristically* about its

⁶ A potentially more efficient choice would be $F((x_0, x_1)) = (x_0, E'(x_1, x_0))$, which uses a block cipher E' with half the block length of E , exploiting the fact that C needs to ensure collision resistance while F does not. In the ideal cipher model, such a construction is still heuristically multi-user oneway.

collision resistance. This approach avoids having to create an argument of knowledge over an idealized component, which would raise questions as to how it needs to be modeled in order for such an argument to exist. Moreover, it provides a natural separation in a scheme's security arguments: An attack against $\mathcal{I}_{KB}$, assuming security of the other components, would translate to a collision finding algorithm against (the real implementation of) C and therefore non-existence of such an algorithm (for whichever reason) implies the unforgeability notion of the theorem.

Theorem 4. *Framework $\mathcal{I}_{KB}$ provides (ϵ_{UF}, q_S) -unforgeability, provided that*

- F is ϵ_{OW} -oneway,
- H is ϵ_{CR_H} -collision resistant,
- C is ϵ_{CR_C} -collision resistant,
- $\mathcal{P}$ is (ϵ_{ZK}, q_S) -zero knowledge and (ϵ_{SSE}, q_S) -simulation-sound extractable

against adversaries of similar runtime, where

$$\epsilon_{UF} \leq \epsilon_{SSE} + \epsilon_{ZK} + \epsilon_{OW} + \epsilon_{CR_H} + 2\epsilon_{CR_C}$$

Proof. The proof is very similar to the proof of Theorem 1. We highlight the differences.

First, algorithm $\mathcal{F}$ becomes (without modification) an algorithm against the collision resistance of C , rather than its unpredictability. This replaces the term ϵ_U in the bound by ϵ_{CR_C} .

Second, we give a different bound for $|p_0 - p_1|$. Recall that the difference between games G_0 (SUF-CMA) and G_1 was that game G_1 would output 0 whenever the pseudonym derived from the forgery was equal to one of the pseudonyms used for signing queried, for a different label.

Denote $r^* := H(pk, l^*)$ and $r_i := H(pk, l_i)$, with l_i the label used in the i -th signing query. Here, we introduce an intermediate game, G'_0 , which shall be identical to G_0 except that it outputs 0 whenever $r^* = r_i$ and $l^* \neq l_i$ for any i . Clearly, this implies a collision in H . Let $\mathcal{B}$ be an algorithm simulating G_0/G'_0 to $\mathcal{A}$ and then outputting such a colliding tuple $((pk, l^*), (pk, l_i))$ if it exists. By assumption on H , we have

$$|p_0 - p'_0| \leq \epsilon_{CR_H}$$

Finally, note that G'_0 and G_1 may only generate different outputs if the same pseudonym is derived from two different randomness values. But this would imply a collision in C . Let $\mathcal{B}'$ be an algorithm simulating G'_0/G_1 to $\mathcal{A}$, but outputting a colliding tuple $((pk, r^*), (pk, r_i))$ if it exists. By assumption on C , we have

$$|p'_0 - p_1| \leq \epsilon_{CR_C}$$

The remainder of the proof of Theorem 1 applies without modification and the present theorem follows by collecting the bounds. $\square$

5 Implementing the Random Oracle

While it is possible to implement H using any hash function, the authors of HKDF argue that when generating too many random bits from a single source of arbitrary keying material, a hash function should not be trusted to produce bits which are pseudorandom [18]. Concretely, this effects the anonymous unlinkability of our scheme, where the sole source of entropy, the public key, is hashed many times with different, adversarially chosen labels.

In this section we describe a variation on $\mathcal{I}_{KB}$, denoted $\mathcal{I}_{SM}$. We show that this variation allows for unlinkability arguments in the standard model, while being compatible with the arguments given in the previous section. The main limitation of this variation is that it increases the public key size. As the authors of [17] argue, removal of a random oracle by itself is not an argument that such alterations will result in a more secure scheme. It should therefore be viewed mainly as a theoretical exercise.

However, the variation naturally leads to an implementation strategy for H in $\mathcal{I}_{KB}$, minimizing the dependence on the random oracle to the extraction of a fixed number of bits from a partially unknown value.

Assume for now that we are given, in addition to the primitives for $\mathcal{I}_{KB}$, the following:

- Sets $\mathcal{S}$, $\mathcal{K}$ and $\mathcal{C}$ of seeds, keys, and context strings
- A function $E : \mathcal{S} \times \mathcal{L} \rightarrow \mathcal{K}$
- A pseudorandom function $G : \mathcal{K} \times \mathcal{C} \rightarrow \mathcal{R}$

$\mathcal{I}_{SM}$ is defined as follows:

Construction $\mathcal{I}_{SM}$

```

def KEYGEN():
     $sk \xleftarrow{\$} SK$ 
     $pk \leftarrow F(sk)$ 
     $s \xleftarrow{\$} \mathcal{S}$ 
    return  $((sk, s), (pk, s))$ 

def BLIND( $(pk, s), l$ ):
     $k \leftarrow E(s, l)$ 
     $r \leftarrow G(k, \text{"blinding"})$ 
     $pk_l \leftarrow C(pk, r)$ 
    return  $pk_l$ 

def SIGN( $(sk, s), m, l$ ):
     $k \leftarrow E(s, l)$ 
     $r \leftarrow G(k, \text{"blinding"})$ 
     $pk_l \leftarrow C(pk, r)$ 
     $\sigma \xleftarrow{\$} \mathcal{P}.Prove((pk_l, m), (sk, r))$ 
    return  $\sigma$ 

def VERIFY( $pk_l, m, \sigma$ ):
    return  $\mathcal{P}.Verify((pk_l, m), \sigma)$ 

```

$\mathcal{I}_{SM}$ differs from $\mathcal{I}_{KB}$ in two aspects. First, both the secret and public key have been augmented with a seed. For clarity and simplicity, when we write of a secret or public key, we are referring to sk and pk , but for practical use

we implicitly assume that the seed is a part of these keys, so they are always conveyed together. In particular, we will assume that an adversary initially not knowing either sk nor pk (as in the anonymous unlinkability game) will also initially not know s .

Second, the hash function H has been implemented using E and G . Below, we will simultaneously require three properties from E . These are randomness extraction from a label, being a pseudorandom function when keyed via s , and collision resistance. For a suitable construction of E and G , please refer to [18].

The distinction between k and r follows the extract-then-expand paradigm outlined in [18] and is a practical one. k may be of a fixed size independent of the required amount of randomness for the commitment scheme (using standard PRF range extension techniques). Additionally, the use of a pseudorandom function allows the secure derivation of further keys by the application requiring key blinding. For instance, GNS encrypts data before signing it using a pseudonym. From our arguments, it should become apparent that additional encryption keys can be derived by executing

$$k_{Enc} \leftarrow G(k, \text{"encryption"})$$

The simplification enabling our standard model argument comes from a separation. While the public key is being committed to, the randomness for the commitment is derived from the independent seed. When attempting to derive a standard model argument for anonymous unlinkability for $\mathcal{I}_{KB}$, one runs into the problem that secrecy of the public key relies on the hiding property of C , which in turn relies on H 's ability to generate random looking output, and this necessarily relies on the secrecy of the public key. While this cyclic dependency could perceivably be resolved using a more involved argument, $\mathcal{I}_{SM}$ sidesteps the issue by making E rely on an independent value.

The size extension of the public key may be undesirable for some applications. For instance, both GNS and Tor encode public keys as domain names, which have a length limit. We therefore reintroduce a random oracle used only for generating s from the public key. Specifically, let $H' : \mathcal{PK} \rightarrow \mathcal{S}$ be a hash function. We propose $\mathcal{I}'_{KB}$, a framework identically to $\mathcal{I}_{KB}$, but with the hash function H implemented by the following procedure:

```

1: def  $H(pk, l)$ :
2:    $s \leftarrow H'(pk)$ 
3:    $k \leftarrow E(s, l)$ 
4:    $r \leftarrow G(k, \text{"blinding"})$ 
5:   return  $r$ 
6:
```

We require H' to derive per public key a single value s , so as to be pseudorandom to any adversary gaining some limited amount of information about pk via its commitments. Below, we argue this to be the case for a random oracle: To gain any knowledge about s by querying H' implies querying it on pk , which (assuming enough initial entropy in public keys) implies a weakness in the extended blinding routine consisting of E , G and C .

Although we do not formally attempt this here, we conjecture that similar reasoning can be applied when replacing H' by a quantum random oracle. We sketch the argument below.

We now formally state our unlinkability arguments for $\mathcal{I}_{SM}$ and $\mathcal{I}'_{KB}$. Due to their similarity, the below theorems cover both of these schemes. For targeted unlinkability, we require E to act as a randomness extractor.

Theorem 5. *Let H' be modeled as a random oracle and $\mathfrak{D}$ be a distribution of labels. Then both $\mathcal{I}_{SM}$ and $\mathcal{I}'_{KB}$ provide $(\epsilon_{TUL}, q_B, q_S)$ -targeted unlinkability w.r.t. $\mathfrak{D}$, provided that*

- E is a (ϵ_E, q_B) -extractor w.r.t. $\mathfrak{D}$,
- G is (ϵ_G, q_B, q_B) -multiuser-pseudorandom,
- C is (ϵ_H, q_B) -hiding,
- $\mathcal{P}$ is (ϵ_{ZK}, q_S) -zero knowledge

against adversaries of similar runtime, where

$$\epsilon_{TUL} \leq 2\epsilon_{ZK} + 2\epsilon_E + 2\epsilon_G + \epsilon_H$$

Proof. The proof argues that the key derivation consisting of E and G produces independent and uniform looking randomness for the commitment scheme. Due to a lack of space, we have deferred it to Appendix D.3. $\square$

For anonymous unlinkability, we require E to act as a pseudorandom function.

Theorem 6. *Let H be modeled as a random oracle permitting q_H queries. Then*

- $\mathcal{I}_{SM}$ provides $(\epsilon_{AUL}, q_B, q_S)$ -anonymous unlinkability, and
- $\mathcal{I}'_{KB}$ provides $(\epsilon'_{AUL}, q_B, q_S)$ -anonymous unlinkability

provided that

- $\mathfrak{D}_F$ has min-entropy h_F
- C is (ϵ_H, q_B) -hiding,
- $\mathcal{P}$ is (ϵ_{ZK}, q_S) -zero knowledge,
- E is (ϵ_E, q_B, q_B) -multiuser-pseudorandom,
- G is (ϵ_G, q_B, q_B) -multiuser-pseudorandom

against adversaries of similar runtime, where

$$\begin{aligned} \epsilon_{AUL} &\leq 2\epsilon_{ZK} + 2\epsilon_E + 2\epsilon_G + \epsilon_H \\ \epsilon'_{AUL} &\leq 4\epsilon_{ZK} + 4\epsilon_E + 4\epsilon_G + 3\epsilon_H + 2q_B \cdot q_H \cdot 2^{-h_F} \end{aligned}$$

Proof. For $\mathcal{I}_{SM}$, the pseudorandomness of E and G ensures proper commitment randomness. For $\mathcal{I}'_{KB}$, we additionally need to argue that an adversary is unlikely to query H' with one of the q_B public keys used for blinding. As before, this follows from the fact that doing so with any advantage better than brute force implies that the keys were not well hidden by the commitment routine. We have deferred the full proof to Appendix D.4. $\square$

The worrisome q_B factor is not matched by a generic attack. Indeed, if one is willing to model E as a random oracle as well, then assuming that the H' digests of the public keys for blinding do not collide (which happens with probability roughly $q_B^2/|S|$), E takes the role of H in $\mathcal{I}_{KB}$, and is domain separated by the label. The above bound provides a second (weaker) safeguard under milder assumptions.

It is easy to see in $\mathcal{I}_{SM}$ that collision resistance of E , G and C implies collision resistance for the blinding routine, enabling cryptographers to apply the arguments given in the previous section. In combination, $\mathcal{I}_{SM}$ provides the (to our knowledge) first standard model construction for key blinding signature schemes.

Open Problem We believe that it is possible to conduct essentially the above analysis for $\mathcal{I}'_{KB}$ in the QROM. The main difference would be to bound $|p_0 - p_1|$ using the O2H theorems of [1]. This however introduces a square root into the argument's bound, covering not only the brute-force search term (which is justified by Grover's algorithm), but the entire bound of p'_1 (roughly defined as the classical event *Find*, which is returned by the corresponding reductions). However, we are unaware of any matching attacks with a quadratic speedup over the post-quantum security of the primitives.

We leave it as an open problem to determine whether $\mathcal{I}'_{KB}$ is substantially less secure than $\mathcal{I}_{SM}$ in the QROM.

6 Efficiently Recognizable Key Blindings

As a final contribution, our goal in this section is to construct a key blinding signature scheme which is anonymously unlinkable and unforgeable, but which is not targeted unlinkable. The combination of anonymous unlinkability and efficient recognizability may be of independent interest, as it allows an individual to create many seemingly unrelated signatures, but allow certain allies to efficiently recognize messages by giving them the public key.

Towards such a construction, let $E : \mathcal{PK} \times \mathcal{R} \rightarrow \mathcal{R}$ be a block cipher and consider the following “commitment scheme”:

$$C(pk, r) := (r, E(pk, r))$$

For any reasonable block cipher, this construction is not hiding. Given two random public keys and a commitment (c_1, c_2) to one of them, the public key being committed to will satisfy $c_2 = E(pk, c_1)$, while pseudorandomness of E would imply that for the independent second public key, this relation occurs with probability roughly $\frac{1}{|\mathcal{R}|}$.

In the context of $\mathcal{I}_{KB}$, this implies that anyone in possession of a public key can efficiently recognize blindings of this key without knowing the label used for the blinding process, and thus the absence of targeted unlinkability.

To achieve anonymous unlinkability, we require pseudorandom public keys. Intuitively, this ensures that blindings appear as random strings, thus not giving any information about the used (public) keys. Using another block cipher $E' : \mathcal{SK} \times \mathcal{PK} \rightarrow \mathcal{PK}$ and a fixed public key pk_0 , we define the following one-way function:

$$F(sk) := E'(sk, pk_0)$$

See [7], Appendix D, for an argument relating the one-wayness of this function to the pseudorandomness of E' .

Let $\mathcal{I}_{ER}$ (“Efficiently Recognizable”) denote $\mathcal{I}_{KB}$ instantiated using C and F .

Theorem 7. *Let H be modeled as a random oracle permitting q_H queries. Then framework $\mathcal{I}_{ER}$ provides $(\epsilon_{AUL}, q_B, q_S)$ -anonymous unlinkability, provided that*

- E' is $(\epsilon_{E'}, q_B, q_B)$ -multiuser-pseudorandom,
- E is (ϵ_E, q_B, q_B) -multiuser-pseudorandom,
- $\mathcal{P}$ is (ϵ_{ZK}, q_S) -zero knowledge

against adversaries of similar runtime, where

$$\epsilon_{AUL} \leq 2\epsilon_{ZK} + 2\epsilon_{E'} + \frac{2q_H}{|\mathcal{PK}|} + 4 \cdot \epsilon_E$$

Proof. We only sketch the argument due to its similarity with earlier proofs. Let $\mathcal{A}$ be an algorithm. We define a series of games. Let G_0 be the original AUL-CMA game against $\mathcal{I}_{ER}$.

Let G_1 be identical to G_0 except that signing queries are answered by the simulator Sim . By assumption on $\mathcal{P}$ and a reduction analogously to the ones given in previous theorems, we have

$$|p_0 - p_1| \leq \epsilon_{ZK}$$

Let G_2 be identical to G_1 except that the up to q_B public keys used in blinding queries are generated as random values. By a standard reduction to the pseudorandomness of E' , we have that⁷

$$|p_1 - p_2| \leq \epsilon_{E'}$$

Let G_3 be identical to G_2 except that blindings of key choose a random $r \xleftarrow{\$} \mathcal{R}$ for each label. By the same reduction strategy of previous theorems, the adversary may only notice this with probability at most

$$|p_2 - p_3| \leq \epsilon_E + \frac{q_H}{|\mathcal{PK}|}$$

⁷ The attentive reader might notice that we never specified the behaviour of $\mathcal{P}.Sim$ for statements not in the NP-relation. However, if such a simulator could distinguish the potentially wrong statements we make use of from true ones, it would contradict the pseudorandomness of E' by this very reduction.

Let G_4 be identical to G_3 except that blinded keys are chosen randomly during any blinding queries. By a standard reduction to the pseudorandomness of E , we have that

$$|p_3 - p_4| \leq \epsilon_E$$

Finally, in G_4 , the view of $\mathcal{A}$ is independent of b , and thus $p_4 = \frac{1}{2}$.

Collecting the bounds yields the theorem. $\square$

Next, we turn to unforgeability. Our argument is based on a weak form of collision resistance arising from the interplay of the random oracle and E , if modeled as an ideal cipher. Define the function $f : \mathcal{L} \times \mathcal{PK}^2 \rightarrow \mathcal{R}^2$ as

$$f(l, pk, pk') = (H(pk, l), E(pk', H(pk, l)))$$

Lemma 3. *Let $H : \mathcal{PK} \times \mathcal{L} \rightarrow \mathcal{R}$ be a random oracle and $E : \mathcal{PK} \times \mathcal{R} \rightarrow \mathcal{R}$ be an ideal cipher permitting q_H and q_E queries, respectively. For f , no algorithm can output a collision of the form $((\hat{l}_0, \hat{pk}_0, \hat{pk}_0), (\hat{l}_1, \hat{pk}_1, \hat{pk}_1))$ (where the first element has a duplicate key) except with probability*

$$\frac{\frac{1}{2}(q_H + 2)^2 + (q_E + q_H + 2)}{|\mathcal{R}|}$$

Proof. The proof of this lemma has been deferred to Appendix D.5 for lack of space. $\square$

Finally, as before, we state the above oracle-heuristic as an explicit assumption to form an argument for unforgeability.

Theorem 8. $\mathcal{I}_{ER}$ is (ϵ_{UF}, q_S) -unforgeable, provided that

- F is ϵ_{OW} -oneway,
- $\mathcal{P}$ is (ϵ_{ZK}, q_S) -zero knowledge and (ϵ_{SSE}, q_S) -simulation-sound extractable,
- the function f defined above is ϵ_{CR} -resistant against collisions of the form in Lemma 3

against adversaries of similar runtime, where

$$\epsilon_{UF} \leq \epsilon_{SSE} + \epsilon_{ZK} + \epsilon_{OW} + 2\epsilon_{CR}$$

Proof. The present theorem follows easily from the proof of theorem 1 by noting that all collisions derived by reductions in this theorem are of the form required by Lemma 3. Namely, the pseudonym involved in the forgery is honestly blinded and thus uses the same public key for H and C . $\square$

Acknowledgments. To be added.

Disclosure of Interests. The authors have no competing interests to declare that are relevant to the content of this article.

References

1. Ambainis, A., Hamburg, M., Unruh, D.: Quantum security proofs using semi-classical oracles. In: Boldyreva, A., Micciancio, D. (eds.) *Advances in Cryptology – CRYPTO 2019, Part II. Lecture Notes in Computer Science*, vol. 11693, pp. 269–295. Springer, Cham, Switzerland, Santa Barbara, CA, USA (Aug 18–22, 2019). https://doi.org/10.1007/978-3-030-26951-7_10
2. Balumuri, S., Eaton, E., Lamontagne, P.: Quantum-safe public key blinding from MPC-in-the-head signature schemes. *Cryptology ePrint Archive*, Report 2024/945 (2024), <https://eprint.iacr.org/2024/945>
3. Beullens, W., Delpéch de Saint Guilhem, C.: LegRoast: Efficient post-quantum signatures from the Legendre PRF. In: Ding, J., Tillich, J.P. (eds.) *Post-Quantum Cryptography - 11th International Conference, PQCrypto 2020*. pp. 130–150. Springer, Cham, Switzerland, Paris, France (Apr 15–17, 2020). https://doi.org/10.1007/978-3-030-44223-1_8
4. Boneh, D., Dagdelen, Ö., Fischlin, M., Lehmann, A., Schaffner, C., Zhandry, M.: Random oracles in a quantum world. In: Lee, D.H., Wang, X. (eds.) *Advances in Cryptology – ASIACRYPT 2011. Lecture Notes in Computer Science*, vol. 7073, pp. 41–69. Springer Berlin Heidelberg, Germany, Seoul, South Korea (Dec 4–8, 2011). https://doi.org/10.1007/978-3-642-25385-0_3
5. Celi, S., Griffy, S., Hanzlik, L., Kempner, O.P., Slamanig, D.: SoK: Signatures with randomizable keys. *Cryptology ePrint Archive*, Report 2023/1524 (2023), <https://eprint.iacr.org/2023/1524>
6. Chase, M., Derler, D., Goldfeder, S., Orlandi, C., Ramacher, S., Rechberger, C., Slamanig, D., Zaverucha, G.: Post-quantum zero-knowledge and signatures from symmetric-key primitives. In: Thuraisingham, B.M., Evans, D., Malkin, T., Xu, D. (eds.) *ACM CCS 2017: 24th Conference on Computer and Communications Security*. pp. 1825–1842. ACM Press, Dallas, TX, USA (Oct 31 – Nov 2, 2017). <https://doi.org/10.1145/3133956.3133997>
7. Chase, M., Derler, D., Goldfeder, S., Orlandi, C., Ramacher, S., Rechberger, C., Slamanig, D., Zaverucha, G.: Post-quantum zero-knowledge and signatures from symmetric-key primitives. *Cryptology ePrint Archive*, Report 2017/279 (2017), <https://eprint.iacr.org/2017/279>
8. Denis, F., Eaton, E., Lepoint, T., Wood, C.A.: Key Blinding for Signature Schemes. Internet-Draft draft-irtf-cfrg-signature-key-blinding-07, Internet Engineering Task Force (Sep 2024), <https://datatracker.ietf.org/doc/draft-irtf-cfrg-signature-key-blinding/07/>, work in Progress
9. Diffie, W., Hellman, M.E.: New directions in cryptography. *IEEE Transactions on Information Theory* **22**(6), 644–654 (1976). <https://doi.org/10.1109/TIT.1976.1055638>
10. Dobraunig, C., Kales, D., Rechberger, C., Schofnegger, M., Zaverucha, G.: Shorter signatures based on tailor-made minimalist symmetric-key crypto. In: Yin, H., Stavrou, A., Cremers, C., Shi, E. (eds.) *ACM CCS 2022: 29th Conference on Computer and Communications Security*. pp. 843–857. ACM Press, Los Angeles, CA, USA (Nov 7–11, 2022). <https://doi.org/10.1145/3548606.3559353>
11. Eaton, E., Lepoint, T., Wood, C.A.: Security analysis of signature schemes with key blinding. *Cryptology ePrint Archive*, Report 2023/380 (2023), <https://eprint.iacr.org/2023/380>
12. Eaton, E., Stebila, D., Stracovsky, R.: Post-quantum key-blinding for authentication in anonymity networks. In: Longa, P., Ràfols, C. (eds.) *Progress in Cryptology - LATINCRYPT 2021: 7th International Conference on Cryptology and*

- Information Security in Latin America. Lecture Notes in Computer Science, vol. 12912, pp. 67–87. Springer, Cham, Switzerland, Bogotá, Colombia (Oct 6–8, 2021). https://doi.org/10.1007/978-3-030-88238-9_4
13. Edoardo Persichetti: Classic mceliece update (2024). URL: <https://csrc.nist.gov/Presentations/2024/classic-mceliece> (4 2024)
 14. Hopper, N.: Proving security of tor’s hidden service identity blinding protocol tor project tech report 2013-12-001
 15. Ishai, Y., Kushilevitz, E., Ostrovsky, R., Sahai, A.: Zero-knowledge from secure multiparty computation. In: Johnson, D.S., Feige, U. (eds.) 39th Annual ACM Symposium on Theory of Computing. pp. 21–30. ACM Press, San Diego, CA, USA (Jun 11–13, 2007). <https://doi.org/10.1145/1250790.1250794>
 16. Kiltz, E., Lyubashevsky, V., Schaffner, C.: A concrete treatment of Fiat-Shamir signatures in the quantum random-oracle model. In: Nielsen, J.B., Rijmen, V. (eds.) Advances in Cryptology – EUROCRYPT 2018, Part III. Lecture Notes in Computer Science, vol. 10822, pp. 552–586. Springer, Cham, Switzerland, Tel Aviv, Israel (Apr 29 – May 3, 2018). https://doi.org/10.1007/978-3-319-78372-7_18
 17. Kobitz, N., Menezes, A.: Critical perspectives on provable security: Fifteen years of “another look” papers. Cryptology ePrint Archive, Report 2019/1336 (2019), <https://eprint.iacr.org/2019/1336>
 18. Krawczyk, H.: Cryptographic extraction and key derivation: The HKDF scheme. In: Rabin, T. (ed.) Advances in Cryptology – CRYPTO 2010. Lecture Notes in Computer Science, vol. 6223, pp. 631–648. Springer Berlin Heidelberg, Germany, Santa Barbara, CA, USA (Aug 15–19, 2010). https://doi.org/10.1007/978-3-642-14623-7_34
 19. Schanzenbach, M., Bramm, G., Schütte, J.: reclaimid: Secure, self-sovereign identities using name systems and attribute-based encryption. In: 2018 17th IEEE International Conference On Trust, Security And Privacy In Computing And Communications/12th IEEE International Conference On Big Data Science And Engineering (TrustCom/BigDataSE). pp. 946–957. IEEE (2018)
 20. Schanzenbach, M., Grothoff, C., Fix, B.: The GNU Name System. RFC 9498 (Nov 2023). <https://doi.org/10.17487/RFC9498>, <https://www.rfc-editor.org/info/rfc9498>
 21. Schnorr, C.P.: Efficient identification and signatures for smart cards. In: Brassard, G. (ed.) Advances in Cryptology – CRYPTO’89. Lecture Notes in Computer Science, vol. 435, pp. 239–252. Springer, New York, USA, Santa Barbara, CA, USA (Aug 20–24, 1990). https://doi.org/10.1007/0-387-34805-0_22
 22. Shor, P.W.: Polynomial-time algorithms for prime factorization and discrete logarithms on a quantum computer. SIAM review **41**(2), 303–332 (1999)
 23. The TOR Project: Tor rendezvous specification - version 3. URL: <https://spec.torproject.org/rend-spec/index.html>
 24. Wahby, R.S., Boneh, D., Jeffrey, C., Poon, J.: An airdrop that preserves recipient privacy. In: Boneau, J., Heninger, N. (eds.) FC 2020: 24th International Conference on Financial Cryptography and Data Security. Lecture Notes in Computer Science, vol. 12059, pp. 444–463. Springer, Cham, Switzerland, Kota Kinabalu, Malaysia (Feb 10–14, 2020). https://doi.org/10.1007/978-3-030-51280-4_24

A Background Information on Applications

A.1 GNU Name System and higher level Protocols

The GNU Name System (GNS), which has been published as RFC 9498 [20], is best thought of as an alternative to the Domain Name System (DNS), offering similar functionality while avoiding many of the historical problems, like zone enumeration and complete transparency of queried domains.

Conceptually, all data (for instance, IP addresses) is stored in encrypted form under a particular label (e.g. “www”) within zones (think “example.com”). Rather than using dedicated name servers, this information is stored with redundancy (for caching) within the network, specifically in a distributed hash table (DHT).

To prevent users other than the zone owner from publishing records in any given zone, the identifier of a zone is a signature key. However, signing data records directly using this key would enable zone enumeration, e.g. by observing the records being propagated through the DHT and checking which records have signatures validating under a given zone key. Instead, the zone key is blinded using each label, and the pseudonymous key is used to sign any data for that label.

Furthermore, the pseudonym serves as a lookup key. Applications wishing to resolve data records under label “www” in a zone with public key pk calculate the lookup key $Blind(pk, \text{“www”})$, and use it to resolve, verify and decrypt the data records. As with the DNS, zone delegation is enabled through special delegation data records, which contain the necessary information for lookups in delegated zones (in this case, that zone’s public key).

The attack vector of zone enumeration naturally highlights why targeted unlinkability is necessary: An adversary wishing to enumerate a zone typically knows that zone’s public key. The usual definition of (anonymous) unlinkability however does not guarantee that such an adversary cannot find all records within a zone. This would still be possible, for instance, with the construction in Section 6.

Some higher level protocols rely on GNS’s zone enumeration resistance specifically. For instance, re:claimID [19] implements Self-Sovereign Identities (SSI) by publishing personally identifiable information at random labels within a zone.

A.2 Tor Rendezvous Protocol

The Tor project aims to provide anonymous communication channels on the internet. It implements a notion of Sender Anonymity via onion routing, in which network peers forward each other’s messages several times and multiple layers of encryption ensure that each peer only knows that each peer on a “circuit” only knows the peer before and after it.

Tor also allows to reach services, the location of which itself remains unknown. This “Receiver Anonymity” is established by having the “Hidden Service” connect via onion routing to several nodes in the network, called “Introduction

Points”. Clients may contact the service by likewise connecting to any “Introduction Points” and having it relay traffic between the two peers.⁸

At regular intervals, each hidden service publishes its current introduction points in an encrypted fashion in a distributed hash table. A public key, which serves as the service’s primary identifier⁹ is used to derive the encryption key and could be used to authenticate the hidden service descriptors including the introduction points. However, to ensure that validation in the DHT is possible without enabling decryption, a pseudonym of the public key is used instead. The security notion justifying this is anonymous unlinkability.

Interestingly, the design documents mention that the label may also include an optional secret. While such a secret was never used, according to one of the developers, the intention probably would have been to ensure that without knowledge of this secret, lookups and linking of the onion services should not be feasible.¹⁰ Such a security notion would require targeted unlinkability.

B Additional Preliminaries

One-Way Functions A function $f : \mathcal{X} \rightarrow \mathcal{Y}$ is called (ϵ, t) -oneway if for every algorithm $\mathcal{A}$ running in time t it holds that $\Pr_{x \leftarrow \mathcal{X}}[f(\mathcal{A}(f(x))) = f(x)] \leq \epsilon$.

It is called (ϵ, u, t) -multiuser-oneway if

$$\Pr[f(x_i) = f(x^*) : (x_1, \dots, x_u) \xleftarrow{\$} \mathcal{X}^u, (x^*, i) \xleftarrow{\$} A(f(x_1), \dots, f(x_u))] \leq \epsilon.$$

Pseudorandom Functions A function $F : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{Y}$ is called (ϵ, t, q) -pseudorandom if for every algorithm $\mathcal{A}$ running in time t and performing at most q oracle queries it holds that $|\Pr_{k \leftarrow \mathcal{K}}[\mathcal{A}^{F(k, \cdot)}() = 1] - \Pr_{f \xleftarrow{\$} \mathcal{Y}^{\mathcal{X}}}[\mathcal{A}^f() = 1]| \leq \epsilon$.

It is called (ϵ, u, t, q) -multiuser-pseudorandom if

$$|\Pr_{(k_1, \dots, k_u) \xleftarrow{\$} \mathcal{K}^u}[\mathcal{A}^{F^{u}}() = 1] - \Pr_{f^u \xleftarrow{\$} \mathcal{Y}^{[u] \times \mathcal{X}}}[\mathcal{A}^{f^u}() = 1]| \leq \epsilon$$

where $F^u(i, x) := F(k_i, x)$.

If $F(k, \cdot)$ is an efficiently invertible bijection for every $k \in \mathcal{K}$, F is called a pseudorandom permutation, or block cipher. In this case we abuse notation and write $F^{-1}(k, \cdot)$ for its inverse.

Hash Functions A function $H : \mathcal{X} \rightarrow \mathcal{Y}$ is called (ϵ, t) -collision-resistant if for every efficiently constructable¹¹ algorithm $\mathcal{A}$ running in time t it holds that

$$\Pr[x_1 \neq x_2 \wedge H(x_1) = H(x_2) : (x_1, x_2) \xleftarrow{\$} \mathcal{A}()] \leq \epsilon.$$

⁸ Application layer data is not transmitted over the introduction point, but rather a different node agreed on over the introduction point.

⁹ Canonically encoded as a “.onion” domain

¹⁰ <https://archive.torproject.org/websites/lists.torproject.org/pipermail/tor-dev/2024-May/014892.html>

¹¹ There always exist efficient collision-finding algorithms for compressing functions in theory. Our reductions are explicit constructions of such algorithms.

Randomness Extractors Let $\mathfrak{D}$ be a probability distribution over $\mathcal{X}$. A function $E : \mathcal{S} \times \mathcal{X} \rightarrow \mathcal{Y}$ is called a (computational, seed-reusable) (ϵ, q, t) -extractor w.r.t. $\mathfrak{D}$ if for every algorithm $\mathcal{A}$ running in time at most t it holds that

$$|\Pr[\mathcal{A}(s, E(s, x_1), \dots, E(s, x_q)) = 1] - \Pr[\mathcal{A}(s, y_1, \dots, y_q) = 1]| \leq \epsilon$$

where $s \xleftarrow{\$} \mathcal{S}$, $(x_1, \dots, x_q) \xleftarrow{\$} \mathfrak{D}$ and $(y_1, \dots, y_q) \xleftarrow{\$} \mathcal{Y}$.

Non-Interactive Zero Knowledge Arguments Let $\mathfrak{R} \subseteq \mathcal{X} \times \mathcal{W}$ be an efficiently decidable binary relation, called an NP-relation. For $(x, w) \in \mathfrak{R}$, we call x the *statement* and w a *witness*.

A non-interactive argument system (NIZK) for $\mathfrak{R}$ is a set of four algorithms $(\text{Prove}, \text{Verify}, \text{Sim}, \text{Ext})$ such that

- $\pi \xleftarrow{\$} \text{Prove}(x, w)$ creates an argument of knowledge of w for a statement x if $(x, w) \in \mathfrak{R}$, else returns $\perp$,
- $0/1 \leftarrow \text{Verify}(x, \pi)$ verifies an argument of knowledge,
- $\pi \xleftarrow{\$} \text{Sim}(x)$ is a zero-knowledge simulator (see below), and
- $w \xleftarrow{\$} \text{Ext}(x, \pi)$ is a witness extractor (see below).

Depending on the model used, Sim and Ext may require various degrees of access to a common reference string, a reprogrammable random oracle or interaction with the adversary (usually via rewinding). We do not consider such details in this paper, but note that our core construction can provide these capabilities to simulators and extractors whenever we make use of them.

We require that $\text{Verify}(x, \pi) = 1$ for all $(x, w) \in \mathfrak{R}$, $\pi \xleftarrow{\$} \text{Prove}(x, w)$, except with negligible probability.

A NIZK is said to be zero-knowledge if an adversary cannot distinguish between the outputs of $\text{Prove}(x, w)$ and the outputs of $\text{Sim}'(x, w)$, defined to be $\text{Sim}(x)$ if $(x, w) \in \mathfrak{R}$ and $\perp$ else. Specifically, a NIZK is (ϵ, t, q) -zero-knowledge if for every adversary $\mathcal{A}$ running in time t and making at most q oracle queries, we have that

$$|\Pr[\mathcal{A}^{\text{Prove}}() = 1] - \Pr[\mathcal{A}^{\text{Sim}'}() = 1]| \leq \epsilon$$

Furthermore, a NIZK is said to be simulation-sound extractable if every adversary creating new proof-statement pairs, after having seen several simulated pairs, must know a witness to these statements. Formally, consider game SSE in Figure 8. A NIZK is (ϵ, t, q) -simulation-sound-extractable if for every adversary $\mathcal{A}$ running in time at most t and making at most q simulation queries, we have that

$$|\Pr[\text{SSE}_{\mathcal{I}}^{0, \mathcal{A}}()] - \Pr[\text{SSE}_{\mathcal{I}}^{1, \mathcal{A}}()]| \leq \epsilon()$$

Game $\text{SSE}_{\mathcal{I}}^{b,\mathcal{A}}()$

1: $Q \leftarrow \emptyset$ 2: $(x, \pi) \leftarrow \mathcal{A}^{\text{Sim}'}()$ 3: $\text{valid} \leftarrow [[(x, \pi) \notin Q \wedge \text{Verify}(x, \pi) = 1]]$ 4: $w \leftarrow \text{Ext}(x, \pi)$ 5: return $[\text{valid} \wedge (b = 1 \Rightarrow (x, w) \notin \mathfrak{R})]$	$\text{Sim}'(x)$ 1: $\pi \leftarrow \text{Sim}(x)$ 2: $Q \leftarrow Q \cup \{(x, \pi)\}$ 3: return π
---	--

Fig. 8: Simulation-Sound Extractability security game

C Gaps in earlier Publications

C.1 Independent Blinding

Eaton et al. [12] present a generic security argument for (anonymous) unlinkability in their lemma 2. It applies to an adversary making no signature queries and to blinding routines of the form

$$pk_l \leftarrow \text{RandBlind}(pk, H(pk, l))$$

where H is a hash function modelled as a random oracle and RandBlind is the actual blinding function. We explain the gap in their argument using our language. By analogy with commitment schemes, the argument assumes that RandBlind exhibits a hiding-like property the authors call “Independent Blinding”. Their argument is structured as follows:

Let G_0 be the original (anonymous) unlinkability game with no signature queries. Let G_1 be identical to G_0 except that blinding queries calculate

$$pk_l \leftarrow \text{RandBlind}(pk, r)$$

where r is sampled randomly with each query, independent of H . Clearly the adversary can only distinguish G_0 and G_1 by making an oracle query of the form $H(pk, \cdot)$. Call this event “bad”.

Next, let G_2 be identical to G_1 except that blinding queries calculate

$$pk_l \leftarrow \text{RandBlind}(pk', r)$$

where also pk' is sampled randomly with each query. The authors argue correctly that any distinguisher between G_0 and G_1 violates the hiding-like Independent Blinding.

Finally, the authors use the fact that “bad” is simple to bound in G_2 , because the view of the adversary is independent of pk . However, “bad” may have a different probability in G_2 than it has in G_0 or G_1 . This gap is left unaddressed.

It is possible to fill the gap by observing that if the probabilities of “bad” differ between G_1 and G_2 , then the predicate “bad” distinguishes G_1 and G_2 . This can be used to construct an adversary virtually identical to the one in Figure 6, showing that the probabilities differ by at most the hiding-like Independent Blinding advantage.

However, this fix introduces a factor of 2 in the concrete bound given by the lemma in [12]. It is unclear whether or not the concrete bound given is meaningful.

C.2 PRF based Key Blinding

Balumuri et al. [2] have constructed a key blinding signature scheme as follows: Given a PRF (the details of which are irrelevant for our discussion), a random 128-bit secret key sk is used to encrypt a fixed plaintext x (of sufficient length) into a public key pk :

$$pk \leftarrow PRF(sk, x)$$

To blind this public key, the public key is encrypted again using a 128-bit blinding factor:

$$\begin{aligned} r &\leftarrow H(pk, l) \\ pk_l &\leftarrow PRF(r, pk) \end{aligned}$$

The signature routine is a proof of knowledge of (sk, r) , which is not relevant to the present discussion. The unforgeability of their scheme can be broken in roughly 2^{64} steps as follows:

Given a public key to attack, generate roughly 2^{64} labels and hash them until you arrive at a collision of the form

$$H(pk, l_1) = H(pk, l_2)$$

This works because r is of length 128 bits. Next, obtain a signature σ on an arbitrary message m for label l_1 . Finally, output (l_2, m, σ) .

This constitutes a valid forgery, since $pk_{l_1} = pk_{l_2}$ and m was never signed for label l_2 .

We have informed the authors and the vulnerability has been fixed in the most current version of their work by increasing the size of the blinding factor.

D Deferred Proofs

D.1 Lemma 1

Proof. Let $\mathcal{A}$ be a PPT adversary against the hiding property of C and let $\mathcal{B}$ denote an adversary against the pseudorandomness of E , defined as a wrapper around $\mathcal{A}$. $\mathcal{B}$ chooses a bit $b \xleftarrow{\$} \{0, 1\}$ and answers $\mathcal{A}$'s oracle queries (x_0, x_1) by forwarding x_b to its own oracle and xor-ing the result with x_b . It then outputs 1 whenever the bit output by $\mathcal{A}$ equals b .

If $\mathcal{B}$'s oracle responds with random values, $\mathcal{A}$'s view is independent of b and thus $\mathcal{B}$ will output 1 with probability $\frac{1}{2}$. If $\mathcal{B}$'s oracle instead encrypts its input using randomly chosen keys, $\mathcal{B}$ is perfectly simulating C to $\mathcal{A}$. Because the

probability of $\mathcal{B}$ outputting 1 may deviate from $\frac{1}{2}$ by at most ϵ by assumption, so does the probability of $\mathcal{A}$ outputting b . Hence, $\mathcal{A}$ can distinguish values of b with advantage at most 2ϵ . $\square$

D.2 Lemma 2

Proof. Assume that the adversary queries the ideal cipher using values corresponding to the elements it outputs and that it never issues queries to which it knows the answer based on previous queries. If necessary, this can be ensured by a wrapper around $\mathcal{A}$ making at most two additional queries. Let $(r_1, \dots, r_{q+2})$ denote a series of random elements in $\mathcal{X}$, whose statistical difference from honest, per-key nonrepeating query answers is at most $\frac{(q+2)^2}{2|\mathcal{X}|}$. If the cipher oracle answers the i -th query with block q_i using r_i , this fixes a uniformly random commitment value $r_i \oplus q_i$, two of which will collide with probability at most $\frac{(q+2)^2}{2|\mathcal{X}|}$. $\square$

D.3 Theorem 5

Proof. Note that the attacker-known, but not attacker-influenced value s is chosen uniformly at random from the set of seeds, either in *KeyGen* or internally by the random oracle. The random oracle does not play a role in the remaining argument.

Let $\mathcal{A}$ be an algorithm. We will construct a series of games G_0 - G_3 with associated winning probabilities p_0 through p_3 . Let G_0 be the original AUL-CMA game against either construction (our arguments apply to both equally) and let G_1 be equal to G_0 with the exception that signing queries are handled by the zero knowledge simulator. Clearly, $\epsilon_{TUL} := 2|p_0 - \frac{1}{2}|$ and an algorithm constructed analogously to $\mathcal{B}$ in Theorem 2 shows that

$$|p_0 - p_1| \leq \epsilon_{ZK}$$

Let game G_2 be identical to G_1 except that the (up to) q_B outputs of E calculated by the game are replaced by independent random values. Let $\mathcal{C}$ be an algorithm taking as input a value for s and q_B further values k_i , $i \in [q_B]$. $\mathcal{C}$ simulates games G_1/G_2 to $\mathcal{A}$, except embedding s into the public key given to the adversary and taking $k \leftarrow k_i$ during the i -th blinding query instead of calculating it using E . If the values k_i given to $\mathcal{C}$ are randomly chosen, the distribution of values given to $\mathcal{A}$ matches the one in game G_1 . If they are chosen as $d_i \xleftarrow{\$} \mathcal{D}$, $k_i \leftarrow E(s, d_i)$, it matches game G_2 . By assumption on E , we have

$$|p_1 - p_2| \leq \epsilon_E$$

Finally, let G_3 be identical to G_2 , except that we replace the outputs of G calculated by the game with random values. Let $\mathcal{D}$ be an algorithm against the multi-user pseudorandomness of G , simulating games G_2/G_3 to $\mathcal{A}$, except taking the value r during the i -th blinding query to be the output of its own oracle on

input $(i, \text{"blinding"})$.¹² Depending on whether the oracle given to $\mathcal{D}$ simulates G or a random function, the distribution of blinded keys given to $\mathcal{A}$ equals the one in game G_2 or G_3 . By assumption on G , we thus get

$$|p_2 - p_3| \leq \epsilon_G$$

In G_3 , the only dependence on b^* visible to the adversary is in whether pk or the newly generated keys are being committed to. A reduction constructed analogously to algorithm $\mathcal{C}$ of Theorem 2 shows that

$$2|p_3 - \frac{1}{2}| \leq \epsilon_H$$

Collecting the bounds yields the theorem. $\square$

D.4 Theorem 6

Proof. Let $\mathcal{A}$ be an algorithm. We construct a series of games G_0 - G_4 . In each game we will be concerned with two probabilities. We let p_i denote the adversary's probability of winning game G_i and p'_i denote the probability that the adversary queries H' with one of the public keys used for blinding in G_i .

Let G_0 and G_1 be the AUL-CMA security game against $\mathcal{I}'_{KB}$ and $\mathcal{I}_{SM}$, respectively. It is clear that $\epsilon'_{AUL} \leq 2|p_0 - \frac{1}{2}|$ and $\epsilon_{AUL} \leq 2|p_1 - \frac{1}{2}|$. Furthermore, $\mathcal{A}$'s views in G_0 and G_1 are identical unless $\mathcal{A}$ queries H' for one of these public keys chosen in these games. Hence

$$|p_0 - p_1| \leq p'_1$$

Let G_2 be identical to G_1 except that signing queries are answered using the simulator Sim . Let $\mathcal{B}$ and $\mathcal{B}'$ be algorithms in the zero-knowledge security game, simulating G_0/G_1 to $\mathcal{A}$, but creating proofs by invoking their oracle. $\mathcal{B}$ returns the output of the simulated games, while $\mathcal{B}'$ returns the 1 iff a public key queried by $\mathcal{A}$ at the random oracle coincides with a public key used for blinding. By assumption on $\mathcal{P}$, we have

$$|p_1 - p_2| \leq \epsilon_{ZK} \geq |p'_1 - p'_2|$$

Let G_3 be identical to G_2 except that the outputs of E are replaced by uniformly random values. Let $\mathcal{C}$ and $\mathcal{C}'$ be algorithms against the pseudorandomness of E , simulating G_2/G_3 to $\mathcal{A}$ but invoking their own oracle for blinding queries with input (i, l) , where i is an index for the up to q_B keys being blinded by the game. $\mathcal{C}$ and $\mathcal{C}'$ determine their output in the same way as $\mathcal{B}$ and $\mathcal{B}'$. By assumption on E , we have

$$|p_2 - p_3| \leq \epsilon_E \geq |p'_2 - p'_3|$$

¹² If an application requires additional keying material, it can be assumed random starting from this step. The reduction would then issue additional queries to the PRF oracle.

Let G_4 be identical to G_3 except that the outputs of G are replaced by uniformly random values. Let $\mathcal{D}$ and $\mathcal{D}'$ be algorithms against the pseudorandomness of G , simulating G_3/G_4 to $\mathcal{A}$ but invoking their own oracle on input on input $(i, \text{"blinding"})$ instead of evaluating G in the i -th blinding query. $\mathcal{D}$ and $\mathcal{D}'$ determine their output in the same way as $\mathcal{B}$ and $\mathcal{B}'$. By assumption on G , we get

$$|p_3 - p_4| \leq \epsilon_G \geq |p'_3 - p'_4|$$

Finally, reductions constructed analogously to algorithms $\mathcal{C}$ and $\mathcal{D}$ of Theorem 3 can be used to argue that

$$p'_4 \leq \epsilon_H + q_B \cdot q_H \cdot 2^{-h_F}$$

$$2|p_4 - \frac{1}{2}| \leq \epsilon_H$$

The q_B factor comes from the fact that the random oracle is no longer domain separated by the labels, hence the oracle can simultaneously search for the up to q_B public keys used for blinding. Collecting the bounds yields the theorem. $\square$

D.5 Lemma 3

Proof. Assume that an adversary has queried H for both elements of a colliding pair (for at most $q_H + 2$ queries) and denote by h_i the output of the i -th H -query (pk_i, l_i) . Assume further that for each such h_i the adversary has queried $E(pk_i, h_i)$ (for at most $q_E + q_H + 2$ queries) and denote the result t_i .

By a birthday bound, we have $h_i = h_j$ for $i \neq j$ with probability no more than $\frac{1}{2}(q_H + 2)^2/|\mathcal{R}|$. Henceforth assume that all h_i are distinct and therefore no collision with $(\hat{l}_1, \hat{p}k_1) \neq (\hat{l}_0, \hat{p}k_0)$ is found.

A collision of the required form implies that for some i , t_i was the result of a query to $E(\hat{p}k'_1, h_i)$ with $\hat{p}k'_1 \neq pk_i$. Let pk' be any key used $q_{pk'}$ times in a query of the form $E(pk', h_i)$ where $pk' \neq pk_i$. The two independent random permutations $E(pk', \cdot)$ and $E(\hat{p}k'_1, \cdot)$ give the same output on one input on average.¹³ The queried values h_i thus give rise to a collision with probability at most $\frac{q_{pk'}}{|\mathcal{R}|}$. Summing over all keys pk' yields the lemma. $\square$

¹³ To see this, fix a permutation σ and note that $Sym(\mathcal{R})$ can be partitioned into size- $|\mathcal{R}|$ equivalence classes by cyclic shifts. For each $r \in \mathcal{R}$, each equivalence class contains exactly one permutation σ' such that $\sigma'(r) = \sigma(r)$.